CASE STUDY

The Year 2017 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

Two days define 2017 in this record: a Friday in May and a Tuesday in June. On Friday 12 May, ransomware that spread on its own through an old Windows file-sharing protocol locked computers in more than 150 countries and disrupted at least 81 of the 236 hospital trusts in England [15][16]. On Tuesday 27 June, malware hidden in an update for a Ukrainian accounting program spread through company networks around the world; the US government later called it "the most destructive and costly cyber-attack in history" and attributed it to the Russian military [18][21]. Both worms carried exploits for a Windows flaw that Microsoft had fixed on 14 March [4], weeks before a group calling itself the Shadow Brokers made the exploits public [9].

The year did not end there. In July, Equifax found that intruders had been inside its online dispute portal since mid-May through an Apache Struts flaw published in March; the count of affected people grew from 143 million to about 147 million as the record closed [10][13][14]. Official software updates turned out to be the delivery route three times: M.E.Doc in Ukraine, NetSarang's server tools and the CCleaner utility [77][28][29]. In December, FireEye's Mandiant team described malware built to reprogram the safety controllers that shut down an industrial plant before it becomes dangerous [25]. Yahoo raised its 2013 breach to every one of about three billion accounts [32]. Uber disclosed a 2016 theft a year late, and the FTC later found it had paid the intruders $100,000 through its bug bounty program [39][40].

The government record of 2017 is mostly a record of naming and rule-making. The United States and five allies attributed WannaCry to North Korea on 19 December [41]. The year produced Executive Order 13800, New York's financial cybersecurity regulation, the order to remove Kaspersky products from federal systems, the first public charter of the US Vulnerabilities Equities Process and an SEC Cyber Unit [80][81][31][84][83]. Most of the indictments, sanctions and attributions that close the year's events came later, from 2018 to 2021, and this study dates them as they were published.

This study is the dated record of that year, built only from sources opened on 11 November 2026. NotPetya, Bad Rabbit, WannaCry's attribution, the Shadow Brokers, Triton, Dragonfly and Equifax each have a home study in this collection; this record gives each a summary and a link, and keeps the dates, costs and controls together in one place. Every row carries its date, the source that supports it and an evidence grade.

> Evidence grade: advisories, indictments (as allegations), sanctions, regulator and audit findings, company filings, the vendor's own research, CVE, NVD, MSRC and KEV records, and the live ATT&CK pages are **Confirmed** from the issuing body. A vendor's attribution assessment, and findings that one organization relays from another (ESET's M.E.Doc backdoor analysis as Talos relays it, Microsoft's statement that the WannaCry exploits came from the NSA), are **Reported**. Where this study draws its own conclusion, or maps described behavior to ATT&CK on its own reading, it says **Inferred**.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2017, plus 2016 events first reported in 2017 (the second Shamoon 2 wave, Uber's 2016 theft) and the later records, from 2018 to 2026, that close 2017 events
Widest outbreak	WannaCry, 12 May 2017: tens of thousands of infections in over 150 countries (US-CERT); hundreds of thousands of computers (White House); 300,000 computers including 48 NHS trusts (UK Foreign Office) [15][41][44]
Costliest outbreak	NotPetya, 27 June 2017: Merck reports, for a 27 June network cyber-attack it does not name (tie Inferred), about $135 million of unfavorable sales effect and about $175 million of expenses for the third quarter; FedEx puts its TNT Express hit at $0.79 per diluted share; DOJ alleges nearly $1 billion in losses at three named victims [19][20][48]
Health care impact	NHS England: at least 81 of 236 trusts disrupted, 603 other NHS organisations infected (595 GP practices), 6,912 appointments known cancelled and more than 19,000 estimated; no NHS body paid [16]
Largest breach disclosures	Equifax: about 143 million US consumers (8-K, 7 September), at least 145.5 million (GAO), about 147 million (FTC settlement) [10][12][14]; Yahoo: all of about three billion accounts from the August 2013 theft (3 October) [32]
Patch window	MS17-010 shipped 14 March 2017 (Confirmed [4]); WannaCry struck 59 days later and NotPetya 105 days later (Inferred arithmetic [4][15][18])
Update-channel compromises	M.E.Doc updates of 14 April, 15 May and 22 June; NetSarang packages of 17 July; CCleaner 5.33 of 15 August, with 2.27 million users affected [77][86][28][29][30]
Safety-system attack	Triton against Triconex safety controllers; ATT&CK campaign C0030 runs June to August 2017 at a petrochemical organization [89][25]
State attributions published	WannaCry to North Korea (19 Dec 2017); NotPetya to the Russian military (15 Feb 2018); Cloud Hopper to APT10 for China's MSS (20 Dec 2018); Triton tooling to Russia's TsNIIKhM (Treasury) [41][21][22][8][50]
Rules of the year	EO 13800 (11 May), NYDFS Part 500 (1 March), BOD 17-01 (13 September), SEC Cyber Unit (25 September), VEP charter (15 November), NDAA FY2018 section 1634 (12 December) [80][81][31][83][84][82]
Reported crime	FBI IC3 2017: 301,580 complaints and more than $1.4 billion in reported losses; 1,783 ransomware complaints (more than $2.3 million adjusted losses); 15,690 BEC and EAC complaints (more than $675 million) [71]
2017 CVEs later in KEV	86 entries in catalog 2026.11.10, 20 flagged for known ransomware use, none added in 2017 because KEV began in November 2021 [5]
This study's MITRE binding	68 Enterprise and 28 ICS technique rows, 10 groups, 15 software objects and 7 campaigns, CWE and CAPEC bindings for the year's CVEs and update compromises, D3FEND pairings, and two Navigator layers (Part 12)

Key findings

- **One patch decided the year's two biggest outbreaks.** MS17-010 fixed the SMBv1 flaws on 14 March and marked each "Exploited: No" (Confirmed [4]). WannaCry spread through those flaws from 12 May and NotPetya used the same exploits from 27 June (Confirmed [15][18]). The NAO found every infected NHS body ran unpatched or unsupported Windows (Confirmed [16]).
- **Credentials moved the attackers more than exploits did.** CISA names the modified Mimikatz, used with WMIC or PsExec, as NotPetya's first and, in most cases, most effective spreading method, with the SMB exploits after it (Confirmed [18]). Dragonfly cracked hashes leaked by forced SMB authentication and logged in to single-factor VPN, RDP and webmail (Confirmed [34]); the MSP intruders used stolen administrator credentials (Confirmed [88]); Equifax's intruders used unencrypted stored credentials to reach 48 more databases (Confirmed [13]). Reading credential theft as the common thread is this study's view (Inferred).
- **The trusted channel was the delivery route.** M.E.Doc's own update server carried NotPetya's backdoor (Confirmed [86][18]); CCleaner 5.33 carried a valid Piriform signature (Confirmed [29]); NetSarang's installers were signed with NetSarang's certificate (Reported [28]); the MSP intrusions reached customers in at least 12 countries through their providers (Confirmed [88]).
- **NotPetya was not ransomware in any useful sense.** CISA says it behaves "more like destructive malware" and that paying is unlikely to recover data, and ATT&CK says it is better thought of as a wiper (Confirmed [18][87]).
- **Equifax was not a single missed patch.** GAO lists four factors (identification, detection, segmentation and data governance) plus no limit on query frequency, an alert that went to an out-of-date list, a scan that missed the portal and an inspection device whose certificate had been expired for about 10 months (Confirmed [13]).
- **Detection often came by luck.** A researcher's kill switch limited WannaCry in the NHS (Confirmed [16]); Triton was found when a flaw in the malware tripped the safety system (Confirmed [89][25]); Equifax saw the intrusion only after renewing the expired certificate (Confirmed [13]).
- **The safety layer became a target.** Mandiant reported an attacker reprogramming Triconex safety controllers from an SIS engineering workstation and assessed that the shutdown was likely an accident while building a capability for physical damage (Confirmed for the findings, Reported for the assessment [25]).
- **The release-day exploitation flag understated the year's worst bugs.** CVE-2017-0199, CVE-2017-11882 and every MS17-010 CVE were marked "Exploited: No" at release; all are now in KEV with known ransomware use (Confirmed [72][73][92][5]; the reading is Inferred).

Top recommendations

1. **Close SMB at the edge and between workstations, and retire SMBv1.** TA17-132A, TA17-181A and TA17-293A all ask for SMB blocked at the boundary, and TA17-181A adds host firewalls that block workstation-to-workstation traffic; the NAO says managed internet-facing firewalls would have protected NHS bodies whatever their patch state (Confirmed [15][18][34][16]).
2. **Patch a known-exploited flaw on a clock and verify the patch landed.** Equifax ordered patching within 48 hours, but nobody verified it (Confirmed [14]); NHS Digital issued critical alerts in March and April, and the Department of Health had no formal way to check compliance (Confirmed [16]).

3. **Know which systems run the vulnerable component.** Equifax's alert went to an out-of-date list and a scan a week later missed the portal (Confirmed [13]). An asset inventory that names the owner is the control that failed (Inferred).
4. **Treat software updates and service providers as privileged access.** Restore to a state before the compromised version, as Talos advised for CCleaner, and validate providers' security as TA17-117A advises (Confirmed [29][88]).
5. **Remove the credential path.** Multi-factor authentication on external, remote and privileged access; credential resets; limits on remote WMI and PsExec; least privilege (Confirmed [34][18][88]).
6. **Segment safety and control networks, and lock their programming mode.** No dual-homed SIS engineering workstations, the hardware key kept out of PROGRAM outside scheduled changes, unidirectional gateways and allowlisting on hosts that can reach the SIS (Confirmed [25][91]).
7. **Keep tested backups off the network, and do not count on paying.** TA17-132A asks for backups kept away from the local network, and TA17-181A warns that NotPetya victims are unlikely to recover data even after paying (Confirmed [15][18]).
8. **Disclose on a clock.** Uber paid its intruders through its bug bounty and waited a year to disclose; the FTC expanded its settlement over it (Confirmed [40]).

Scope and method

This study covers intrusions, campaigns, exploited vulnerabilities, leaks and the government response dated to calendar year 2017, plus 2016 events that were first reported in 2017 and the later records (indictments, sanctions, audits, settlements, catalog entries) that close a 2017 event. It follows the method of the case studies collection: primary sources first, every claim graded, numbers as the source states them, and every source opened on 11 November 2026.

Grade	Meaning in this study
Confirmed	The primary source was opened and states the fact: a government advisory, directive or statement, a court or charging document (cited as allegations), a sanctions notice, an audit or regulator finding, a company filing or statement, the vendor's own research or bulletin, a CVE, NVD, MSRC or KEV record, the live ATT&CK page, or the library's own data files
Reported	The fact rests on a source relaying another party's finding, or on a vendor's attribution assessment that no government record states
Demonstrated	Public proof-of-concept code exists; it shows a flaw can be used, not that it was. No 2017 claim in this study rests on this grade
Inferred	This study's own reasoning or arithmetic, or an ATT&CK mapping that no source prints, labelled where it appears

Limits that a reader should know:

- **Pages read from archive copies.** The DOJ releases on the Park Jin Hyok complaint, the GRU Unit 74455 indictment, the Yahoo indictment, the PLA Equifax indictment, SamSam, Kelihos, AlphaBay, BTC-e and the Mirai pleas, the MSRC customer guidance of 12 May 2017 and Europol's Andromeda release were read from Internet Archive snapshots of the cited addresses, because the live pages serve a bot

check, a JavaScript shell or a redirect. The cited URL is the original address.

- **Pages that did not open.** The UK NCSC's own NotPetya attribution page now reports the page removed; the UK government's release on the same assessment [22] is cited instead. The CISA malware analysis report on HatMan did not open; the Tricon advisory [91] carries the HatMan findings used here. The Nuance 10-Q and 10-K that the SEC full-text search returns were not opened in full [43].
- **Vendor counts are vendor counts.** FBI complaint totals are self-reported [71]; Avast's user counts, Cloudflare's leak rate and Europol's sinkhole figures (which Europol cites to Microsoft) describe what each organization saw [30][2][70].
- **Attribution is reported as the source gives it.** A vendor's "moderate confidence" stays moderate; an indictment is an allegation; the US, UK and allied statements are dated to the day they were made, not to the event.
- **Home studies.** NotPetya and Bad Rabbit live in the Sandworm study; WannaCry's attribution narrative in the North Korea-attributed actors study; the Shadow Brokers and Vault 7 in the United States-attributed actors study; Triton and Dragonfly in the Russia-attributed actors study; Equifax and Cloud Hopper in the China-attributed actors study; Shamoon in the Iran-attributed actors study; the NetSarang and CCleaner attribution question in the APT41 study. Each is summarized here in a paragraph (Confirmed for the home studies' coverage [27]).
- **Tradecraft is described at advisory level.** Technique names and ids only; no commands, exploit details, payload strings or ransom notes.

Part 1: the year as a dated timeline

One row per event or report. The date is the event date where the source gives one, otherwise the publication date. Later records that close a 2017 event follow in a second table.

Date	Event	Thread	Grade	Sources
2016-11-29 (reported 2017-01-09)	Unit 42 reports a second Shamoon 2 wave set to wipe at 01:30 Saudi time at a second Saudi organization, using a 64-bit Disttrack variant (Shamoon, S0140). Home study: Iran-attributed actors	Destructive	Confirmed	[1]
2017-02-18	Tavis Ormandy reports the Cloudbleed parser bug to Cloudflare; memory could leak from 22 Sep 2016, most of all from 13 to 18 Feb 2017, in about 1 in 3,300,000 HTTP requests (Cloudflare report, 23 Feb)	Vulnerability, cloud	Confirmed	[2]
2017-03-01	NY DFS promulgates 23 NYCRR Part 500, which it calls the first-in-the-nation cybersecurity regulation	Government	Confirmed	[81]
2017-03-07	WikiLeaks publishes Vault 7 Part 1, "Year Zero": 8,761 documents and files it says came from the CIA Center for Cyber Intelligence (publication Confirmed; provenance is WikiLeaks' claim)	Leak	Confirmed	[3]

Date	Event	Thread	Grade	Sources
2017-03	Apache Struts bulletin S2-045 (CVE-2017-5638): remote code execution in the Jakarta Multipart parser through the Content-Type header; fixed in 2.3.32 and 2.5.10.1; Critical	Vulnerability	Confirmed	[6]
2017-03-10	Unidentified individuals scan Equifax for the Struts flaw US-CERT had identified two days earlier and find the online dispute portal (GAO)	Data breach	Confirmed	[13]
2017-03-11	NVD publishes CVE-2017-5638 (CWE-755) and notes exploitation in the wild in March 2017	Vulnerability	Confirmed	[7]
2017-03-14	Microsoft publishes MS17-010 (KB4013389), Critical: SMBv1 remote code execution CVE-2017-0143, 0144, 0145, 0146 and 0148 and information disclosure CVE-2017-0147, each "Exploited: No"	Vulnerability	Confirmed	[4]
2017-03-15	DOJ charges two FSB officers and two criminal hackers over the Yahoo intrusion, a conspiracy from January 2014 that took data from at least 500 million accounts (allegations)	State, data breach	Confirmed	[53]
2017-04-03	NCSC publishes mitigation guidance for the campaign against managed service providers later known as Cloud Hopper	State	Confirmed	[8]
2017-04-08 to 2017-04-10	FBI domain blocking begins on 8 April; DOJ announces action against the Kelihos botnet on 10 April	Crime	Confirmed	[66]
2017-04-14	First backdoored M.E.Doc update (10.01.175-176); TA17-181A dates a backdoor in M.E.Doc's development environment to the same day	Supply chain	Confirmed (CISA, Talos); Reported (ESET's DLL analysis)	[18][86][77]
2017-04-15	Microsoft's MSRC triages the exploits the Shadow Brokers made public: EternalBlue, EternalChampion, EternalRomance and EternalSynergy already fixed by MS17-010; three others do not reproduce on supported platforms	Leak, vulnerability	Confirmed	[9]
2017-04-27	TA17-117A: intrusions at IT service providers used to reach customers in at least 12 countries, with PlugX and RedLeaves	State, supply chain	Confirmed	[88]
2017-04 to 2017-05	GRU Unit 74455 officers spear phish Macron's En Marche party, French politicians and local governments before the French elections (indictment allegation)	State	Confirmed	[48]
2017-05-11	Executive Order 13800 signed (Federal Register, 16 May): agencies to use the NIST Framework immediately	Government	Confirmed	[80]
2017-05-12	WannaCry (S0366) first reported around 04:00 EDT; spreads through SMBv1 (MS17-010, EternalBlue) on TCP 445; NHS England hit	Ransomware, worm	Confirmed	[15][16]

Date	Event	Thread	Grade	Sources
2017-05-12 to 2017-05-13	Microsoft releases security updates for custom-support platforms (Windows XP, Windows 8, Server 2003)	Vulnerability	Confirmed	[62][15]
2017-05-13	Equifax intrusion begins extracting data; about 9,000 queries follow over about 76 days	Data breach	Confirmed	[13]
2017-05-14	Microsoft says WannaCrypt used exploits stolen from the NSA and repeats its call for a Digital Geneva Convention (Microsoft's claim)	Policy	Reported	[63]
2017-05-14	FireEye assesses APT32 (OceanLotus) operations as aligned with Vietnamese state interests	State	Reported	[60]
2017-05-15	Second backdoored M.E.Doc update (10.01.180-181)	Supply chain	Confirmed	[86][77]
2017-05-18	XData ransomware appears, mostly in Ukraine, created right after M.E.Doc ran (ESET, with TeleBots as the actor)	Ransomware, supply chain	Confirmed (findings); Reported (actor link)	[17]
2017-05 (from at least)	APT activity against energy, nuclear, water, aviation, critical manufacturing and government (TA17-293A)	State, ICS	Confirmed	[34]
2017-05-31	Date of a web shell found on M.E.Doc's update server (Talos)	Supply chain	Confirmed	[86]
2017-06-12	ESET publishes Industroyer (S0604); US-CERT TA17-163A describes CrashOverride the same day. ESET judged it highly probable that Industroyer was used in the December 2016 Ukrainian grid attack, and TA17-163A says CrashOverride was reportedly used against Ukraine in 2016. Home study: Sandworm	ICS	Confirmed (TA17-163A); Reported (ESET's attribution)	[49][79]
2017-06-13	TA17-164A: HIDDEN COBRA's DDoS botnet and DeltaCharlie, the first HIDDEN COBRA alert	State	Confirmed	[24]
2017-06 to 2017-08	ATT&CK campaign C0030, the Triton Safety Instrumented System Attack, at a petrochemical organization (TEMP.Veles, G0088)	State, ICS	Confirmed	[89][26]
2017-06-22	Third backdoored M.E.Doc update (10.01.188-189)	Supply chain	Confirmed	[86][77]
2017-06-27	NotPetya (S0368) surfaces through M.E.Doc and spreads worldwide; Merck, TNT Express, Nuance and Heritage Valley Health System among those hit	Destructive	Confirmed (Merck's and Nuance's ties Inferred from the date)	[18][19][20][64][48]
2017-06-30	ESET reports that Diskcoder.C (NotPetya) was created right after M.E.Doc ran and ties the outbreak to TeleBots	Destructive	Confirmed (findings); Reported (actor link)	[17]
2017-07-01	US-CERT TA17-181A on NotPetya	Destructive	Confirmed	[18]

Date	Event	Thread	Grade	Sources
2017-07-03	The CCleaner compromise may have begun (Avast)	Supply chain	Confirmed	[30]
2017-07-05	Talos publishes "The MeDoc Connection"; the AlphaBay administrator is arrested in Thailand	Supply chain, crime	Confirmed	[86][67]
2017-07-13 and 2017-07-17	NetSarang's backdoored nssock2.dll compiled (13 July) and on NetSarang's site (17 July) in Xmanager, Xshell, Xftp and Xlpd	Supply chain	Confirmed	[28]
2017-07-14	Mathy Vanhoef notifies vendors of KRACK, the WPA2 key-reinstallation flaw (around this date, by the researcher's account)	Vulnerability	Confirmed	[93]
2017-07-18	Avast acquires Piriform, CCleaner's maker	Supply chain	Confirmed	[30]
2017-07-20	DOJ announces the seizure of AlphaBay, alongside the Dutch-led Hansa Market action	Crime	Confirmed	[67]
2017-07-25 to 2017-07-26	Alexander Vinnik arrested in Greece; a 21-count indictment of Vinnik and the BTC-e exchange announced	Crime	Confirmed	[68]
2017-07-29 to 2017-07-30	Equifax discovers the intrusion and takes the dispute portal offline	Data breach	Confirmed	[10][13]
2017-08	A Middle East petrochemical facility attacked with Triton, with tools built by TsNIIKhM (Treasury)	State, ICS	Confirmed	[50]
2017-08-15	Kaspersky publishes ShadowPad (S0596) in NetSarang products; CCleaner 5.33 released with the backdoor	Supply chain	Confirmed	[28][29]
2017-08-28	CERT/CC sends a broad notice on KRACK	Vulnerability	Confirmed	[93][35]
2017-09-06	Symantec's Dragonfly report, as TA17-293A dates it	State, ICS	Confirmed	[34]
2017-09-07	Equifax announces an incident affecting about 143 million US consumers	Data breach	Confirmed	[10][78]
2017-09-12	CCleaner 5.34 released, ending the distribution of 5.33	Supply chain	Confirmed	[29]
2017-09-13	DHS issues BOD 17-01 on Kaspersky-branded products; NVD publishes CVE-2017-8759, which Microsoft marked exploited in its September release	Government, vulnerability	Confirmed	[31][61][75][72]
2017-09-15	CCleaner's command server taken down	Supply chain	Confirmed	[30]
2017-09-18 to 2017-09-19	Talos discloses the CCleaner compromise; Avast puts affected users at 2.27 million; FedEx reports the NotPetya cost	Supply chain, destructive	Confirmed	[29][30][20]
2017-09-20	Mandiant names APT33 (G0064) and assesses it works at the behest of the Iranian government	State	Reported	[58]
2017-09-25	SEC creates a Cyber Unit and a Retail Strategy Task Force	Government	Confirmed	[83]

Date	Event	Thread	Grade	Sources
2017-10-03	Yahoo, through Verizon's 8-K: every account, of about three billion, was affected by the August 2013 theft	Data breach	Confirmed	[32]
2017-10-16	CERT/CC VU#228519: KRACK, CVE-2017-13077 to 13082, 13084 and 13086 to 13088	Vulnerability	Confirmed	[35]
2017-10-20	DHS and FBI TA17-293A on the energy-sector APT campaign	State, ICS	Confirmed	[34]
2017-10-24	Bad Rabbit (S0606) outbreak through compromised websites serving a fake Flash Player update; the Kiev metro among victims; US-CERT calls it a suspected Petya variant	Destructive	Confirmed	[36][37]
2017-10-27	The UK National Audit Office reports on WannaCry and the NHS	Government, health	Confirmed	[16]
2017-11-01	KRACK presented at ACM CCS	Vulnerability	Confirmed	[93]
2017-11-07	Merck's 10-Q reports the cost of the 27 June network cyber-attack (the filing does not name NotPetya; the tie rests on the date, Inferred)	Destructive	Confirmed	[19]
2017-11-14	TA17-318A (FALLCHILL, S0181) and TA17-318B (Volgmer): HIDDEN COBRA tooling; Microsoft patches CVE-2017-11882	State, vulnerability	Confirmed	[46][47][92]
2017-11-15	The US Vulnerabilities Equities Policy and Process charter is dated; NVD publishes CVE-2017-11882 (CWE-119)	Government, vulnerability	Confirmed	[84][75]
2017-11-16	Kaspersky publishes its investigation of the September 2014 Equation detection on a US user's machine (the vendor's own account)	Leak	Confirmed	[38]
2017-11-21	Uber's chief executive discloses the late-2016 theft of data on 57 million users	Data breach, cloud	Confirmed	[39]
2017-11-27	DOJ unseals charges against three Boyusec employees for intrusions at Moody's Analytics, Siemens and Trimble from 2011 to May 2017 (allegations)	State	Confirmed	[56]
2017-11-29	The Andromeda (Gamarue) botnet is dismantled (Europol release, 4 December)	Crime	Confirmed	[70]
2017-12-07	Mandiant reports APT34 exploiting CVE-2017-11882 less than a week after Microsoft's patch	State, vulnerability	Reported	[59]
2017-12-08	Three defendants plead guilty in D. Alaska to creating the Mirai botnet (DOJ announcement, 13 December; the informations and plea agreements are dated 5 December, see Discrepancies). Home study: Five hacks and why they worked: the cases in Fancy Bear Goes Phishing	Crime	Confirmed	[69]

Date	Event	Thread	Grade	Sources
2017-12-12	FY2018 NDAA section 1634 prohibits use of Kaspersky Lab products and services	Government	Confirmed	[82]
2017-12-14	FireEye's Mandiant publishes TRITON	ICS	Confirmed	[25]
2017-12-19	The United States attributes WannaCry to North Korea; the UK, Australia, Canada, New Zealand and Japan join	State	Confirmed	[41][44]

Later records that close 2017 events:

Date	Record	Grade	Sources
2018-02-15	White House and UK government attribute NotPetya to the Russian military; TA17-181A revised	Confirmed	[21][22][18]
2018-03-15	Treasury sanctions the FSB, the GRU and six GRU-linked individuals, citing NotPetya; TA18-074A supersedes TA17-293A and names Russian government cyber actors	Confirmed	[23][52]
2018-04-12	FTC expands its Uber settlement over the 2016 breach and the bug-bounty payment	Confirmed	[40]
2018-06-07	TA17-132A revised to add the attribution of WannaCry to the North Korean government	Confirmed	[15]
2018-08-14	Equifax's SEC correspondence on the March 2017 notice and the UK and Canadian counts	Confirmed	[11]
2018-08-30 (released 2018-09-07)	GAO-18-559 on Equifax	Confirmed	[12][13]
2018-09-06	DOJ unseals the complaint against Park Jin Hyok; Treasury designates him and Chosun Expo Joint Venture	Confirmed (allegations)	[45][42]
2018-11-28	SamSam indictment of two Iranian men unsealed	Confirmed (allegations)	[65]
2018-12-18	ICSA-18-107-02 Update B on the Tricon flaws found during the HatMan investigation	Confirmed	[91]
2018-12-20	DOJ charges two APT10 members; the UK and allies attribute Cloud Hopper to APT10 acting for the MSS; TA17-117A revised	Confirmed	[54][8][88]
2019-07-22	FTC, CFPB and 50 states and territories settle with Equifax for at least $575 million and up to $700 million	Confirmed	[14]
2020-02-10	DOJ charges four members of the PLA 54th Research Institute over Equifax	Confirmed (allegations)	[55]
2020-10-19	DOJ announces the indictment of six GRU Unit 74455 officers, including NotPetya and the En Marche operation	Confirmed (allegations)	[48]

Date	Record	Grade	Sources
2021-06 and 2021-08 (indictment dates)	Indictments of a TsNIIKhM employee (Triton) and three FSB Center 16 officers (Dragonfly 2.0), later unsealed by DOJ	Confirmed (allegations)	[51]
Undated in this record	Treasury designates TsNIIKhM under CAATSA section 224 for building the Triton tools	Confirmed	[50]
2021-11-03 to 2026-03-05	KEV adds 86 CVE-2017 entries, the MS17-010 family between 3 November 2021 and 24 May 2022	Confirmed	[5]

Part 2: the destructive worms

WannaCry (summary; attribution home: North Korea-attributed actors)

WannaCry (S0366) was first reported around 04:00 EDT on Friday 12 May 2017. It exploited the SMBv1 flaws fixed by MS17-010 over TCP 445, scanned local ranges on UDP 137 and 138 and TCP 139 and 445, installed a service named mssecsvc2.0 and checked a kill-switch domain before running (Confirmed [15]). US-CERT counted tens of thousands of infections in over 150 countries; a phishing vector was described as possible but unconfirmed (Confirmed [15]). Microsoft took what it called the "highly unusual step" of releasing updates for custom-support platforms, Windows XP, Windows 8 and Server 2003, and said Windows 10 customers were not targeted (Confirmed [62]); US-CERT dates those updates to 13 May (Confirmed [15]). Two days later Microsoft's president wrote that WannaCrypt used exploits stolen from the NSA, which is Microsoft's claim (Reported [63]). ATT&CK records WannaCry as first seen in a global attack in May 2017 and lists Lazarus Group (G0032) as its user (Confirmed [85]).

The NHS gives the clearest record of what one outbreak costs a health system. The NAO found WannaCry disrupted at least 81 of 236 NHS trusts in England and infected 603 primary care and other NHS organisations, including 595 GP practices; NHS England counted 6,912 cancelled appointments and estimated more than 19,000 (Confirmed [16]). No NHS body paid the ransom. NHS Digital had issued critical patch alerts in March and April, the Department of Health had no formal way to check compliance, the response plan had not been tested locally, and regions hit before a researcher's kill switch took effect saw more infections (Confirmed [16]). Every infected body ran unpatched or unsupported Windows, and the NAO says managed internet-facing firewalls would have protected them whether or not they were patched (Confirmed [16]).

Attribution came in December. On 19 December Tom Bossert, with DHS's Jeanette Manfra, said the United States was comfortable the attack was "directed by the government of North Korea", that Microsoft had traced it to North Korean government affiliates, and that the UK, Australia, Canada, New Zealand and Japan joined the attribution (Confirmed [41]). The UK Foreign Office minister named the Lazarus Group and gave the NCSC's judgement as "highly likely" (Confirmed [44]). In September 2018 DOJ unsealed a complaint alleging that Park Jin Hyok, of the front company Chosun Expo Joint Venture, belonged to the team the private sector calls Lazarus Group and that his conspiracy created the WannaCry 2.0 malware; Treasury designated Park and the company the same day (Confirmed as allegations [45][42]). The 2018 revision of TA17-132A records the attribution (Confirmed [15]).

NotPetya (summary; home: Sandworm, Part 5)

NotPetya (S0368) surfaced on 27 June 2017 through M.E.Doc, Ukrainian tax software whose development environment held a backdoor as early as 14 April (Confirmed [18]). Its first and, in most cases, most effective spreading method was a modified Mimikatz that harvested credentials, used with WMIC or PsExec; it then tried the EternalBlue and EternalRomance SMBv1 exploits, and with administrator rights it modified the master boot record and left machines unusable (Confirmed [18]). CISA says it "behaves more like destructive malware" than ransomware and that recovery is unlikely even after payment; ATT&CK describes it as better thought of as wiper malware (Confirmed [18][87]).

Talos found that every NotPetya ("Nyetya") installation it saw came through M.E.Doc's update channel: an administrator's credentials were stolen, the update server's NGINX configuration was changed to proxy update requests to an outside host, a web shell dated 31 May sat on the server, and backdoored versions went out on 14 April, 15 May and 22 June (Confirmed [86]). Talos assessed with high confidence that the intent was destructive (Confirmed [86]). The backdoored ZvitPublishedObjects.dll, which collected organization identifiers and credentials and polled for commands, is ESET's analysis, relayed by Talos and published by ESET on 4 July (Reported [86][77]). Ukrainian cyber police confirmed more than 2,000 affected companies in Ukraine, as Talos relays it (Reported [86]). ESET reported on 30 June that a smaller ransomware outbreak in May, XData, had also been created right after M.E.Doc ran (Confirmed [17]).

The cost record is in company filings. Merck reported that a network cyber-attack on 27 June disrupted worldwide manufacturing, research and sales, with about $135 million of unfavorable sales effect and about $175 million of expenses for the third quarter and first nine months of 2017 (Confirmed [19]). The 10-Q does not name NotPetya, so the tie rests on the date (Inferred). FedEx said the June 27 NotPetya attack significantly affected TNT Express worldwide and cut first-quarter FY2018 earnings by $0.79 per diluted share (Confirmed [20]). Nuance reported a "June 27, 2017 global malware incident" that disrupted its healthcare transcription and imaging operations, without naming NotPetya; the tie rests on the date (Confirmed for the filing, Inferred for the link [64][43]). The 2020 indictment alleges that Heritage Valley Health System lost mission-critical systems for about a week, and that it, TNT Express and a large US pharmaceutical maker lost nearly $1 billion together (Confirmed as allegations [48]).

Attribution followed in February 2018: the White House said "the Russian military launched" NotPetya, and the UK judged the Russian military "almost certainly responsible", with Ukrainian financial, energy and government sectors as the main targets (Confirmed [21][22]). Treasury's sanctions of 15 March 2018 cite the attack and say several US hospitals could not create electronic records for more than a week (Confirmed [23]). The 2020 indictment of six GRU Unit 74455 officers names the researchers' labels for the group, Sandworm Team, Telebots, Voodoo Bear and Iron Viking, which ATT&CK records as G0034 (Confirmed [48][26]).

Bad Rabbit (summary; home: Sandworm, Part 5)

Bad Rabbit (S0606) broke out on 24 October 2017 through compromised Russian, Ukrainian and other websites that served a fake Flash Player update; the Kiev metro was among the victims, and it spread over SMB with Mimikatz-harvested and hardcoded credentials, with later research reporting EternalRomance (Confirmed [36]). US-CERT reported infections in many countries, called it a suspected Petya variant, named no infection vector and advised against paying (Confirmed [37]). The drive-by vector in this study's ATT&CK table rests on ATT&CK's mapping and ESET's research, not on the US-CERT alert (Confirmed [26][36][37]).

Part 3: state operations

North Korea

Beyond WannaCry, DHS and FBI opened their HIDDEN COBRA series in 2017. TA17-164A of 13 June described DeltaCharlie, malware for managing a North Korean DDoS botnet, and defined HIDDEN COBRA as the US government's name for North Korean government cyber activity, active since 2009 against media, aerospace, financial and critical infrastructure targets (Confirmed [24]); ATT&CK lists HIDDEN COBRA as an alias of Lazarus Group (Confirmed [26]). On 14 November TA17-318A described FALLCHILL (S0181), a remote administration tool "used by the North Korean government" and, citing trusted third-party reporting, likely in use since 2016 against aerospace, telecommunications and finance (Confirmed [46]); TA17-318B described the Volgmer trojan as HIDDEN COBRA tooling (Confirmed [47]). Treasury's 2018 designation of Park Jin Hyok ties WannaCry 2.0 to the Bangladesh Bank theft of February 2016 and the Sony Pictures attack of November 2014 (Confirmed [42]).

Russia

NotPetya and the French election. The GRU Unit 74455 indictment covers both NotPetya and spearphishing and hack-and-leak efforts in April and May 2017 against En Marche, French politicians and local governments; the opened primary names Unit 74455 (Sandworm), not APT28 (Confirmed as allegations [48]).

Dragonfly against energy. DHS and FBI's TA17-293A of 20 October described APT activity since at least May 2017 against government, energy, nuclear, water, aviation and critical manufacturing, using suppliers and other staging targets as pivots; it named no state and cited Symantec's Dragonfly report (Confirmed [34]). Symantec dated Dragonfly 2.0's earliest activity to December 2015, saw strong signs of activity in the US, Turkey and Switzerland, and listed spear-phishing with Phishery template injection, watering holes, trojanized software, fake Flash updates and the Goodor, Dorshel, Karagany.B and Heriplor backdoors, with no zero-days (Confirmed [33]). TA18-074A superseded the 2017 alert in March 2018 and attributed the campaign to "Russian government cyber actors" active since at least March 2016 (Confirmed [52]). In 2021 a grand jury indicted three officers of FSB Center 16 for an energy-sector campaign from 2012 to 2017, whose 2014 to 2017 phase DOJ says is "commonly referred to as Dragonfly 2.0" (Confirmed as allegations [51]). ATT&CK records the group as Dragonfly, G0035 (Confirmed [26]). Home study: Russia-attributed actors.

Triton. See Part 7.

Yahoo. DOJ's March 2017 indictment charged two FSB officers, Dokuchaev and Sushchin, and two criminal hackers, Belan and Baratov, over a conspiracy from January 2014 that took data from at least 500 million Yahoo accounts; one defendant also searched mail for card and gift-card numbers and enabled the theft of contacts from at least 30 million accounts for a spam campaign (Confirmed as allegations [53]). No ATT&CK group applies (Confirmed [26]).

China

Cloud Hopper. TA17-117A of 27 April 2017 described intrusions at IT service providers used to reach their customers in at least 12 countries, with stolen administrator credentials and certificates, PlugX and RedLeaves loaded by DLL side-loading, PowerShell and PowerSploit, and RC4-encrypted command traffic over port 443 (Confirmed [88]). Its body never named APT10; its December 2018 revision attributes the activity to actors associated with China's Ministry of State Security (Confirmed [88]). The NCSC had published mitigation guidance on 3 April 2017 (Confirmed [8]). On 20 December 2018 the UK judged APT10 "almost certainly responsible" for the campaign against managed service providers since at least 2016, "widely known as Cloud Hopper", and the MSS responsible, and DOJ charged Zhu Hua and Zhang Shilong as APT10 members acting in association with the MSS Tianjin State Security Bureau, including an MSP Theft Campaign from at least 2014 into 2018 (Confirmed [8][54]). ATT&CK records APT10 as menuPass, G0045 (Confirmed [26]). Home study: China-attributed actors.

Equifax. In February 2020 DOJ indicted four members of the PLA 54th Research Institute, alleging they exploited the Struts flaw in the dispute portal, ran about 9,000 queries, routed traffic through about 34 servers in nearly 20 countries, used encrypted channels and wiped logs daily, taking personal data of about 145 million Americans (Confirmed as allegations [55]). The release does not give the 2017 intrusion dates (Confirmed [55]); GAO does (Part 6).

Boyusec and APT3. DOJ's November 2017 indictment of Wu Yingzhuo, Dong Hao and Xia Lei of Boyusec covers intrusions at Moody's Analytics, Siemens and Trimble from 2011 to May 2017 by spearphishing, hop points and stolen credentials; it names no government sponsor and does not use the name APT3 (Confirmed as allegations [56]). ATT&CK's G0022 APT3 page says researchers attributed APT3 to the MSS, citing FireEye and Recorded Future in May 2017, so the link from Boyusec to APT3 and the MSS is third-party attribution (Reported [57]).

NetSarang and CCleaner. See Part 5; the attribution discussion lives in the APT41 study.

Iran

Unit 42's January report on the second Shamoon 2 wave is used here for its dates and the 64-bit Disttrack variant, not for attribution (Confirmed [1]); Shamoon's history lives in the Iran-attributed actors study. Mandiant named APT33 (G0064) on 20 September 2017, assessed that "APT33 works at the behest of the Iranian government" and reported aviation and energy targeting through spearphishing (Reported [58]). In December Mandiant reported APT34 (ATT&CK G0049, OilRig) exploiting CVE-2017-11882 less than a week after Microsoft's 14 November patch, with a custom PowerShell backdoor, and assessed it works on behalf of the Iranian government (Reported [59]; patch date Confirmed [92]). The SamSam indictment of November 2018 charged two Iranian men with a ransomware scheme from December 2015 (Part 8); DOJ does not describe it as state activity (Confirmed as allegations [65]).

Vietnam

FireEye assessed in May 2017 that APT32 (OceanLotus, ATT&CK G0050) runs operations "aligned with Vietnamese state interests", against private-sector companies, foreign governments, dissidents and journalists (Reported [60]). Home study: Other state-linked actors.

Part 4: the leaks (summary; home: United States-attributed actors)

Two leaks of state hacking tools shaped the year. On 7 March WikiLeaks published Vault 7 Part 1, "Year Zero", 8,761 documents and files it says came from the CIA's Center for Cyber Intelligence; the publication is Confirmed, the provenance is WikiLeaks' own claim (Confirmed [3]). In April the Shadow Brokers made a set of Windows exploits public. Microsoft's MSRC post, dated 15 April and updated 13 June, triaged them: EternalBlue, EternalChampion, EternalRomance and EternalSynergy were already fixed by MS17-010; EmeraldThread by MS10-061, EsikmoRoll by MS14-068, EducatedScholar by MS09-050 and EclipsedWing by MS08-067; EnglishmanDentist, EsteemAudit and ExplodingCan did not reproduce on supported platforms (Confirmed [9]). Within weeks, the fixed SMB exploits were inside WannaCry and NotPetya (Confirmed [15][18]).

In November Kaspersky published its own account of how classified-marked documents reached its systems: in September 2014 an archive on a US user's machine triggered its Equation signatures and was retrieved, and Kaspersky says the machine was likely compromised by a backdoor in a pirated Office activation tool (Confirmed as the vendor's own account [38]). The US government response to Kaspersky in 2017 was a policy action, not an attributed intrusion: BOD 17-01 cited concern about ties between certain Kaspersky officials and Russian intelligence (Confirmed [61][31]), and the FY2018 NDAA prohibited Kaspersky products (Confirmed [82]).

Part 5: supply chain

Three official update channels carried malware in 2017, two of them with valid signatures (CCleaner Confirmed, NetSarang as Kaspersky reports it), and in each the channel was genuine while the sender was compromised (Inferred from [86][28][29]).

Date	Product	What happened	Grade	Sources
2017-04-14, 2017-05-15, 2017-06-22	M.E.Doc (Ukrainian accounting software)	Backdoored updates 10.01.175-176, 10.01.180-181 and 10.01.188-189 carried ZvitPublishedObjects.dll; the update server's NGINX proxied update requests to an outside host; the channel delivered XData in May and NotPetya on 27 June	Confirmed (Talos, CISA); Reported (ESET's DLL analysis and TeleBots attribution)	[86][18][77][17]
2017-07-17	NetSarang Xmanager, Xshell, Xftp and Xlpd	nssock2.dll backdoored (compiled 13 July) with ShadowPad (S0596); found through suspicious DNS requests at a partner financial institution; an activated payload confirmed at a company in Hong Kong; code similar to PlugX and Winnti, with no attribution asserted	Confirmed (findings); Reported (signing detail and the Hong Kong activation as Kaspersky states them)	[28]
2017-08-15 to 2017-09-12	CCleaner 5.33 (32-bit) and CCleaner Cloud 1.07.3191	Trojanized build signed with a valid Piriform certificate, served from the legitimate download servers until 5.34; build environment likely compromised; 2.27 million users affected and about 730,000 still on the affected version on 19 September; command server down on 15 September	Confirmed	[29][30]

Talos advised restoring to a state before 15 August 2017 or reinstalling (Confirmed [29]). Avast says the compromise may have begun on 3 July, before it bought Piriform on 18 July (Confirmed [30]). Talos calls

CCleaner a supply-chain compromise (Reported as Talos's characterization [29]). Who was behind NetSarang and CCleaner is a later question that the APT41 study takes up; none of the 2017 sources opened here names an actor. Dragonfly 2.0 also used trojanized software (Confirmed [33]), and the library's data maps T1195.002 to both Sandworm Team and Dragonfly at group level (Confirmed [26]). Binding T1195.002 to the three 2017 update compromises is this study's reading of the vendor reports, not a mapping MITRE published for these events (Inferred [26]). The SolarWinds study and the npm supply-chain study carry the same pattern into later years (Inferred).

Part 6: Equifax, Yahoo, Uber and the data record

Equifax (summary; actor home: China-attributed actors)

The record of Equifax is unusually complete because a filing, an audit, a regulator and an indictment all describe it.

Date	Step	Grade	Sources
2017-03	DHS distributes a notice on the Struts vulnerability; Equifax receives it, but its security processes do not identify the exploited application	Confirmed	[11]
2017-03-08 and 2017-03-10	US-CERT identifies the Struts flaw; two days later unidentified individuals scan Equifax for it and find the online dispute portal	Confirmed	[13]
2017-03	Equifax is alerted and orders patching within 48 hours, but nobody verifies the patches (FTC)	Confirmed	[14]
2017-03 (a week after the alert)	The US-CERT notice goes to an out-of-date recipient list; a scan a week later misses the portal	Confirmed	[13]
2017-05-13	A separate intrusion begins extracting data	Confirmed	[13]
2017-05 to 2017-07	The intruders use unencrypted credentials to expand from 3 databases to an additional 48, run about 9,000 queries and remove data in small increments over standard encrypted web protocols; an expired certificate (about 10 months) leaves the inspection device unable to inspect encrypted traffic	Confirmed	[13]
2017-07-29 to 2017-07-30	Signs of intrusion seen after the certificate is replaced; the portal taken offline; about 76 days in all	Confirmed	[13]
2017-09-07	Equifax announces about 143 million US consumers affected, about 209,000 card numbers and about 182,000 dispute documents accessed, UK and Canadian residents also affected	Confirmed	[10][78]
2018-08-14	Equifax: about 19,000 Canadian consumers affected and about 860,000 UK consumers contacted	Confirmed	[11]
2018-08-30	GAO: at least 145.5 million individuals; Equifax's review named identification, detection, segmentation of database access and data governance	Confirmed	[12][13]
2019-07-22	FTC: at least $575 million and up to $700 million, about 147 million people; administrative credentials stored in plain text	Confirmed	[14]
2020-02-10	DOJ charges four PLA members (allegations)	Confirmed	[55]

The vulnerability itself is in the CVE table in Part 9. The CWE that NVD lists for CVE-2017-5638, CWE-755, says nothing about the four process failures GAO found; the weakness that cost Equifax most was organizational (Inferred [7][13]).

Yahoo

Verizon's 8-K exhibit of 3 October 2017 carried Yahoo's finding, under its new Oath name, that every Yahoo user account was affected by the August 2013 theft first disclosed on 14 December 2016, out of about three billion accounts; the stolen data excluded clear-text passwords, payment card data and bank data (Confirmed [32]). The separate 2014 intrusion is the subject of the March 2017 indictment (Part 3) (Confirmed [53]).

Uber

Uber's chief executive said on 21 November 2017 that two outside individuals had accessed user data on a third-party cloud service in late 2016: names, emails and phone numbers of 57 million users worldwide and about 600,000 US driver's license numbers; Uber failed to notify in 2016 and removed two response leaders (Confirmed [39]). The FTC later found that the intruders used an access key an Uber engineer had posted on a code-sharing website to download unencrypted files from the cloud provider, that Uber paid them $100,000 through its bug bounty, and that it did not disclose until November 2017 (Confirmed [40]). The posted key, not the total, is the transferable lesson (Inferred).

Cloudbleed

Cloudflare's own incident report says a parser bug could leak memory from 22 September 2016, with the greatest impact from 13 to 18 February 2017, in about 1 in 3,300,000 HTTP requests; Tavis Ormandy reported it on 18 February (Confirmed [2]). It was a vulnerability in a shared provider, not an intrusion, and no source opened here describes it being exploited (Confirmed [2]).

Part 7: industrial and safety systems

Triton (summary; actor home: Russia-attributed actors)

FireEye's Mandiant team reported on 14 December 2017 that an attacker reached an SIS engineering workstation at a critical-infrastructure organization and used the TRITON framework to reprogram Triconex safety instrumented system controllers over the TriStation protocol; some controllers entered a failed safe state, which shut down the process and prompted the investigation (Confirmed [25]). Mandiant tied it to no actor it tracked, assessed "with moderate confidence that the actor is sponsored by a nation state", and judged the shutdown likely inadvertent while the attacker developed a capability for physical damage (Reported as Mandiant's assessment [25]).

ATT&CK records the operation as campaign C0030, the Triton Safety Instrumented System Attack, run by TEMP.Veles (G0088) against a petrochemical organization, first seen June 2017 and last seen August 2017, and discovered when a safety trip resulted from a flaw in the malware; it lists the software Triton (S1009) and Mimikatz (S0002) (Confirmed [89][26]). Treasury says the facility, in the Middle East, was attacked with Triton in August 2017 with tools customized by Russia's TsNIIKhM, which it designated under CAATSA section 224 (Confirmed [50]). A June 2021 indictment unsealed by DOJ alleges that between May and September 2017 conspirators including Evgeny Gladkikh of TsNIIKhM's Applied Developments Center installed Triton on a Schneider Electric safety system at a foreign refinery, causing two emergency shutdowns (Confirmed as allegations [51]).

CISA's Tricon advisory, ICSA-18-107-02, records two firmware flaws found during the HatMan investigation, CVE-2018-8872 (CVSS v3 9.0) and CVE-2018-7522 (7.9), both CWE-119, in Tricon MP 3008 firmware 10.0 to 10.4, and notes that HatMan needs the controller's key switch in PROGRAM, so controllers should never be left in that mode (Confirmed [91]). ATT&CK's S1009 page, read at content v20.1 and last modified 12 May 2026, lists the aliases TRISIS and HatMan (Confirmed [90]).

CrashOverride and Industroyer (the 2016 grid attack, reported in 2017)

On 12 June 2017 ESET published Industroyer (S0604), with payloads for IEC 60870-5-101, IEC 60870-5-104, IEC 61850 and OPC DA, and called it "highly probable" that it was used in the December 2016 Ukrainian grid attack (ATT&CK C0025) (Reported [49]). US-CERT's TA17-163A described CrashOverride the same day as an extensible ICS attack platform that issues valid commands to RTUs, scans over OPC, carries a wiper and a Siemens relay denial-of-service, and was reportedly used against Ukraine in 2016; it found no evidence of US impact, and a 2021 update attributes it to Russian nation-state actors (Confirmed [79]). The event belongs to 2016; the Sandworm study is its home.

Dragonfly at the control-system edge

TA17-293A records the actors browsing file servers for ICS and SCADA documents and using watering holes on trade and ICS sites (Confirmed [34]); Symantec reported possible access to operational systems (Reported [33]); DOJ's 2021 indictment describes watering holes on ICS trade sites in the 2014 to 2017 phase (Confirmed as allegations [51]). The industrial incidents in the ICS study for 2024 to 2026 show the same move from IT access toward control systems (Inferred), and the Stuxnet study is the earlier precedent for controller tampering (Inferred).

Part 8: crime and law enforcement

Date	Event	Grade	Sources
2017-04-10	Kelihos: DOJ action after FBI domain blocking from 8 April; Peter Levashov allegedly ran the botnet from about 2010; it harvested credentials, sent hundreds of millions of spam emails and installed ransomware and banking malware; the warrant used the amended Rule 41	Confirmed	[66]
2017-07-20	AlphaBay seized alongside the Dutch-led Hansa Market action: more than 250,000 drug and chemical listings and more than 100,000 listings for IDs, access devices, malware and hacking tools; administrator arrested in Thailand on 5 July and died in custody on 12 July	Confirmed	[67]
2017-07-26	BTC-e and Alexander Vinnik indicted (21 counts, N.D. Cal.): more than $4 billion in bitcoin received and funds from the Mt. Gox hack laundered (allegations)	Confirmed	[68]
2017-11-29	Andromeda (Gamarue, ATT&CK S1074 ANDROMEDA) dismantled by the FBI, Luneburg police, EC3, J-CAT, Eurojust and private partners; Europol cites Microsoft for 80 associated malware families, more than 1 million machines a month detected or blocked, and about 2 million unique victim IPs from 223 countries in 48 hours of sinkholing	Confirmed (the Microsoft figures as Europol cites them)	[70]
2017-12-08	Mirai creators plead guilty; two also plead to a clickfraud botnet of more than 100,000 devices (December 2016 to February 2017). Home study: Five hacks and why they worked: the cases in Fancy Bear Goes Phishing	Confirmed	[69]
2015-12 to 2018	SamSam (S0370): a 34-month scheme from December 2015 with more than 200 victims, including hospitals and municipalities, more than $6 million collected and more than $30 million in losses (indictment unsealed 28 Nov 2018; 2017 victims are not dated in the release)	Confirmed (allegations)	[65]

The FBI's IC3 counted 301,580 complaints in 2017 with reported losses above $1.4 billion; ransomware drew 1,783 complaints with adjusted losses above $2.3 million, while business email compromise drew 15,690 with more than $675 million (Confirmed [71]). On the reported numbers, email fraud cost complainants far more than ransomware did in the year of WannaCry and NotPetya (Inferred [71]); the destructive outbreaks hit companies whose costs appear in their filings, not in IC3 complaints (Inferred [19][20][71]).

Part 9: vulnerabilities and exploitation

The CVEs that defined the year

CVE	What	Vendor record at release	NVD (published, CWE)	KEV added, ransomware flag	Sources
CVE-2017-0143	SMBv1 remote code execution (MS17-010)	14 Mar 2017, Critical, Exploited: No	not opened	2021-11-03, Known (KEV CWE-20)	[4][5]
CVE-2017-0144	SMBv1 remote code execution (MS17-010)	14 Mar 2017, Exploited: No	17 Mar 2017, NVD-CWE-noinfo, CVSS 3.1 8.8	2022-02-10, Known (KEV CWE-20)	[4][76][5]
CVE-2017-0145	SMBv1 remote code execution (MS17-010)	14 Mar 2017, Exploited: No	not opened	2022-02-10, Known (KEV CWE-20)	[4][5]
CVE-2017-0146	SMBv1 remote code execution (MS17-010)	14 Mar 2017, Exploited: No	not opened	2022-03-25, Known (KEV CWE-20)	[4][5]
CVE-2017-0147	SMBv1 information disclosure (MS17-010)	14 Mar 2017, Exploited: No	not opened	2022-05-24, Known	[4][5]
CVE-2017-0148	SMBv1 remote code execution (MS17-010)	14 Mar 2017, Exploited: No	not opened	2022-04-06, Known (KEV CWE-20)	[4][5]
CVE-2017-5638	Apache Struts Jakarta Multipart parser remote code execution (S2-045)	Critical; fixed in 2.3.32 and 2.5.10.1	11 Mar 2017, CWE-755 (NVD and CNA), CVSS 3.1 9.8	2021-11-03, Known (KEV CWE-20)	[6][7][5]
CVE-2017-0199	Office and WordPad RTF handling	April 2017, Exploited: No	12 Apr 2017, NVD-CWE-noinfo, 7.8	2021-11-03, Known	[73][75][5]
CVE-2017-11882	Office Equation Editor	14 Nov 2017, Exploited: No	15 Nov 2017, CWE-119, 7.8	2021-11-03, Known	[92][75][5]
CVE-2017-8759	.NET Framework	September 2017, Exploited: Yes	13 Sep 2017, CWE-94	2021-11-03, Unknown	[72][75][5]

KEV names CVE-2017-5638 "Apache Struts Remote Code Execution Vulnerability" (Confirmed [7]). Which leaked exploit name corresponds to which MS17-010 CVE is not stated by any source opened for this study, so the table does not pair them.

Exploited at release, and exploited later

Microsoft's 2017 CVRF data marks 15 items "Exploited: Yes" at release: CVE-2017-0005, 0022 and 0149 in March; ADV170005 and CVE-2017-0210 in April; CVE-2017-0261, 0262, 0263 and 0222 in May; CVE-2017-8464 and 8543 in June; ADV170015 and CVE-2017-8759 in September; CVE-2017-11826 and ADV170018 in October (Confirmed [72]). The 2017 tab of Google Project Zero's "0day In the Wild" tracker lists 22 CVEs, 18 of them Microsoft's, plus Cisco CVE-2017-3881, IBM Domino CVE-2017-1274, Ghostscript CVE-2017-8291 and Adobe Flash CVE-2017-11292; it includes CVE-2017-0143 to 0147, CVE-2017-0199, CVE-2017-0261, 0262 and 0263, CVE-2017-8464, 8543, 8759 and CVE-2017-11826 (Confirmed [74]).

The two lists disagree in the way that matters. CVE-2017-0199, CVE-2017-11882 and every MS17-010 CVE were "Exploited: No" on release day; Project Zero lists CVE-2017-0199 and CVE-2017-0143 to 0147 as 2017 in-the-wild zero-days, and all of them are now in KEV with known ransomware use (Confirmed [72][73][92][74][5]). A release-day exploitation flag describes the day of release, not where a flaw ends up (Inferred).

Named bugs

KRACK, the WPA2 key-reinstallation flaw, covers CVE-2017-13077 to 13082, 13084 and 13086 to 13088, and CERT/CC published VU#228519 on 16 October (Confirmed [35]); by the researcher's own account, Mathy Vanhoef notified the vendors he had tested around 14 July, CERT/CC sent a broad notification to vendors on 28 August, and the work was presented at ACM CCS on 1 November (Confirmed [93]). Cloudbleed is in Part 6 (Confirmed [2]).

2017 CVEs in KEV

The KEV catalog (version 2026.11.10, 1,779 entries) holds 86 CVE-2017 entries, and none was added in 2017 because KEV began in November 2021 (Confirmed [5]). By year added: 14 in 2021, 61 in 2022, 5 in 2023, 2 in 2024, 3 in 2025 and 1 in 2026, the latest being CVE-2017-7921 on 5 March 2026; Microsoft has 29, Cisco 20 and Apache 5 (Confirmed, counts computed from the feed [5]). Twenty carry the known-ransomware flag: the six MS17-010 CVEs, CVE-2017-0199, CVE-2017-11882, CVE-2017-5638 (Struts), CVE-2017-10271 (WebLogic), CVE-2017-12149 (JBoss), CVE-2017-12615 (Tomcat), CVE-2017-9822 (DNN), CVE-2017-18362 (Kaseya VSA), CVE-2017-7494 (Samba), CVE-2017-11357 (Telerik), CVE-2017-1000253 (Linux kernel), CVE-2017-6884 (Zyxel), CVE-2017-0213 and CVE-2017-0101 (Confirmed [5]). A KEV date of 3 November 2021 means "in the first load", not "first exploited that day" (Inferred [5]).

Part 10: the government record

Attribution and enforcement

Date	Body	Action	Subject	Grade	Sources
2017-03-15	DOJ	Indictment of two FSB officers and two hackers	Yahoo, 2014 to 2016	Confirmed (allegations)	[53]
2017-11-27	DOJ	Indictment of three Boyusec employees	Moody's Analytics, Siemens, Trimble	Confirmed (allegations)	[56]
2017-12-19	White House, with the UK, Australia, Canada, New Zealand and Japan	Public attribution	WannaCry to North Korea	Confirmed	[41][44]
2018-02-15	White House; UK government (NCSC assessment)	Public attribution	NotPetya to the Russian military	Confirmed	[21][22]
2018-03-15	Treasury	CAATSA 224 and EO 13694 designations of the FSB, GRU and six individuals	NotPetya cited	Confirmed	[23]
2018-03-15	DHS and FBI	TA18-074A	Dragonfly campaign to Russian government cyber actors	Confirmed	[52]
2018-09-06	DOJ; Treasury	Complaint; designation of Park Jin Hyok and Chosun Expo Joint Venture	WannaCry 2.0	Confirmed (allegations)	[45][42]
2018-12-20	DOJ; UK and allies	Charges against two APT10 members; attribution	Cloud Hopper and the MSP Theft Campaign	Confirmed	[54][8]
2020-02-10	DOJ	Indictment of four PLA members	Equifax	Confirmed (allegations)	[55]
2020-10-19	DOJ	Indictment of six GRU Unit 74455 officers	NotPetya, En Marche	Confirmed (allegations)	[48]
2021 (indictments), unsealed later	DOJ	Indictments of a TsNIIKhM employee and three FSB Center 16 officers	Triton; Dragonfly 2.0	Confirmed (allegations)	[51]
Undated in this record	Treasury	CAATSA 224 designation of TsNIIKhM	Triton	Confirmed	[50]

Rules and directives

- **NYDFS Part 500, 1 March.** New York's Department of Financial Services promulgated 23 NYCRR Part 500 for entities licensed under its Banking, Insurance or Financial Services Law (Confirmed [81]).
- **EO 13800, 11 May.** Agencies to use the NIST Framework immediately and report on risk management to DHS and OMB within 90 days; support for critical infrastructure; a Commerce and DHS botnet report,

preliminary in 240 days and final in one year (Confirmed [80]).

- **BOD 17-01, 13 September.** Federal agencies to identify Kaspersky-branded products within 30 days, submit removal plans within 60 and begin removal at 90, reporting every 30 days after (Confirmed [31][61]).
- **SEC Cyber Unit, 25 September.** Covering hacking for material nonpublic information, market manipulation, DLT and ICO violations, dark-web misconduct, brokerage account intrusions and threats to trading platforms (Confirmed [83]).
- **VEP charter, 15 November.** A monthly Equities Review Board including OMB, ODNI, Treasury, State and DOJ (with the FBI and NCIJTF), with NSA as Executive Secretariat and an annual report with an unclassified executive summary (Confirmed [84]). It followed a year in which leaked state exploits drove the two largest outbreaks; the sources do not say the leaks caused it (Inferred).
- **NDAA FY2018 section 1634, 12 December.** Prohibits use of products and services developed or provided by Kaspersky Lab; the effective date was not read (Confirmed [82]).

Part 11: the defender view

Patch latency was measured in weeks, and boundary control filled the gap. MS17-010 shipped 14 March; WannaCry arrived 59 days later and NotPetya 105 days later (Inferred arithmetic from Confirmed dates [4][15][18]). The NAO's finding that managed internet-facing firewalls would have protected NHS bodies whatever their patch state (Confirmed [16]) is the strongest evidence in the 2017 record for a control that works when patching is late. The library's D3FEND pairing for T1210 includes Network Traffic Filtering (Part 12).

Credentials carried the destructive malware inside. TA17-181A names credential theft with WMIC or PsExec as NotPetya's main spreading method and adds WMI permissioning, host firewalls between workstations, limits on remote WMI and file sharing, and blocking remote PsExec to the usual patch, SMBv1 removal and backup advice (Confirmed [18]). The library has no D3FEND mapping for T1021.002 SMB/Windows Admin Shares, the technique that carries those moves; the controls that apply come from the advisory, not from a D3FEND row (Confirmed [26]).

Service providers were a route, not only a vendor. TA17-117A asked providers to hunt the published indicators and watch for bandwidth anomalies, and asked customers to validate their providers' security, with MFA, least privilege, application allowlisting, central logging, segmentation and passwords of at least 15 characters (Confirmed [88]).

Energy-sector guidance named the egress controls. TA17-293A recommends blocking SMB egress (TCP 139 and 445, UDP 137) and WebDAV at the border, MFA on external, remote and privileged access, credential resets, ICS segmentation, PowerShell 5 module, script-block and transcription logging, one-year central log retention, application allowlisting, and hunting for new administrator accounts and deleted-log events (Confirmed [34]).

Control systems needed their own controls. TA17-163A asks for application allowlisting, authenticated commands to field devices, separate corporate and control credentials, segmented enclaves and gold-image backups of PLC and RTU configurations (Confirmed [79]). Mandiant's Triton guidance adds segregated safety networks, no dual-homed SIS engineering workstations, the hardware key out of PROGRAM outside

scheduled events with change management and audit of key state, unidirectional gateways, allowlisting on hosts that can reach the SIS, and ICS traffic monitoring (Confirmed [25]); the Tricon advisory repeats the PROGRAM-mode warning (Confirmed [91]).

Equifax is an inventory and visibility lesson. The alert reached an out-of-date list, a scan missed the portal, flat database access let 3 databases become 51, no limit applied to query frequency, and an expired certificate blinded the inspection device for about 10 months (Confirmed [13]). The library's D3FEND pairings for T1190 and T1030 include Database Query String Analysis and Per Host Download-Upload Ratio Analysis, which describe the detections that the expired certificate prevented (Inferred [26][13]).

Recovery decided the outcome. TA17-132A asks for tested backups kept off the local network and advises against blocking the kill-switch domain; TA17-181A warns that NotPetya victims are unlikely to recover even after paying (Confirmed [15][18]). Talos's CCleaner remediation was to restore to a state before the compromised version (Confirmed [29]).

The same list recurs. Read together, TA17-132A, TA17-181A, TA17-117A, TA17-293A, TA17-163A and the NAO repeat one set of controls: patch and verify, block SMB at boundaries, MFA on remote access, segment, allowlist, log, and keep offline backups (Inferred [15][18][88][34][79][16]).

Part 12: MITRE mappings

Every id below was checked against the library's data files (`data/attack/technique_profiles.jsonl`, `data/attack/ics/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `data/attack/ics/software.jsonl`, `campaigns.jsonl`, `software_to_technique.jsonl`, `group_to_technique.jsonl`, `technique_to_d3fend.jsonl`, `superseded_by.jsonl`, `data/weaknesses/cwe.jsonl` and `capec.jsonl`) and the generated pages under `mitre/` on 11 November 2026 [26], with the objects that carry 2017 procedures opened on attack.mitre.org [85][87][89][90][57]. Names and tactics are those of ATT&CK v20.0, the library's basis; the live site showed content v20.1 on the S1009 page [90]. Revoked ids are mapped through `superseded_by.jsonl`: TA17-117A's DLL side-loading (T1574.002) is now T1574.001 DLL, Clear Windows Event Logs (T1070.001) is now T1685.005, and Disable or Modify System Firewall (T1562.004) is now T1686 (Confirmed [26]).

The Basis column says how strong each tie is: **Listed** means an ATT&CK object (software, campaign or group, as the library's data records it) or the cited source prints the technique; **Described** means the source describes the behavior and the mapping is this study's; **Reported** means only a Reported source supports the behavior; **Inferred** marks a mapping of described behavior that this study makes with less direct support (the Equifax, Uber and CCleaner fits, and the HIDDEN COBRA DDoS).

ATT&CK Enterprise techniques

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1594	Search Victim-Owned Websites	reconnaissance	Described	Dragonfly campaign, as TA18-074A describes it (15 Mar 2018)	[52]
T1595	Active Scanning	reconnaissance	Listed	C0030, Jun to Aug 2017	[89]
T1595.002	Vulnerability Scanning	reconnaissance	Inferred	Equifax scanned for the Struts flaw, 10 Mar 2017 (GAO)	[13]
T1593.003	Code Repositories	reconnaissance	Inferred	An Uber engineer's access key posted on a code-sharing site, used in late 2016 (FTC)	[40]
T1587.001	Malware	resource-development	Listed	C0030	[89]
T1588.002	Tool	resource-development	Listed	C0030	[89]
T1190	Exploit Public-Facing Application	initial-access	Described	Equifax dispute portal through CVE-2017-5638, from 13 May 2017 (GAO; DOJ allegation)	[13][55]
T1195.002	Compromise Software Supply Chain	initial-access	Described	M.E.Doc updates of 14 Apr, 15 May and 22 Jun 2017; NetSarang, 17 Jul; CCleaner 5.33, 15 Aug; Dragonfly 2.0 trojanized software. The library maps it to G0034 and G0035 at group level; S0368 does not list it	[18][86][77][28][29][33][26]
T1199	Trusted Relationship	initial-access	Described	MSP intrusions (TA17-117A, 27 Apr 2017); the MSP Theft Campaign (DOJ, 2018); Dragonfly staging targets (TA17-293A); the library maps it to G0045	[88][54][34][26]
T1189	Drive-by Compromise	initial-access	Listed	Bad Rabbit via compromised websites, 24 Oct 2017 (S0606; ESET); Dragonfly watering holes (Described)	[26][36][34][33]
T1566	Phishing	initial-access	Described	En Marche spearphishing, Apr to May 2017 (indictment allegation); Boyusec spearphishing (allegation); APT33 (Mandiant, Reported)	[48][56][58]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1566.001	Spearphishing Attachment	initial-access	Described	TA17-293A and TA18-074A; APT34 with CVE-2017-11882, Dec 2017 (Mandiant, Reported)	[34][52][59]
T1133	External Remote Services	persistence, initial-access	Described	Single-factor VPN, RDP and OWA logons with stolen credentials (TA17-293A)	[34]
T1078	Valid Accounts	stealth, persistence, privilege-escalation, initial-access	Described	Stolen administrator credentials at service providers (TA17-117A); TA18-074A; Boyusec stolen credentials (allegation)	[88][52][56]
T1078.003	Local Accounts	stealth, persistence, privilege-escalation, initial-access	Listed	S0368 NotPetya	[87]
T1078.004	Cloud Accounts	stealth, persistence, privilege-escalation, initial-access	Inferred	Uber's posted cloud access key (FTC)	[40]
T1047	Windows Management Instrumentation	execution	Listed	S0366 WannaCry; NotPetya through WMIC (TA17-181A; S0368)	[85][87][18]
T1059.001	PowerShell	execution	Listed	C0030; PowerShell and PowerSploit at service providers (TA17-117A, Described); APT34's PowerShell backdoor (Reported)	[89][88][59]
T1569.002	Service Execution	execution	Listed	NotPetya with PsExec (S0368; TA17-181A); S0606 Bad Rabbit	[87][18][26]
T1053.005	Scheduled Task	execution, persistence, privilege-escalation	Listed	S0368; S0606; C0030; scheduled tasks in the Dragonfly campaign (TA18-074A, Described)	[87][26][89][52]
T1203	Exploitation for Client Execution	execution	Reported	APT34 exploits CVE-2017-11882 within a week of the 14 Nov 2017 patch (Mandiant)	[59]
T1204.002	Malicious File	execution	Listed	Bad Rabbit's fake Flash Player update (S0606; ESET)	[26][36]
T1106	Native API	execution	Listed	S0606	[26]
T1543.003	Windows Service	persistence, privilege-escalation	Listed	WannaCry installs a service (TA17-132A; S0366)	[15][85]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1136	Create Account	persistence	Described	Account creation in the Dragonfly campaign (TA18-074A)	[52]
T1136.001	Local Account	persistence	Described	New local accounts (TA17-293A, 20 Oct 2017)	[34]
T1505.003	Web Shell	persistence	Described	Web shell dated 31 May 2017 on M.E.Doc's update server (Talos); web shells in TA17-293A	[86][34]
T1547.009	Shortcut Modification	persistence, privilege-escalation	Described	LNK manipulation in the Dragonfly campaign (TA18-074A); the .LNK files served credential harvesting more than persistence (Inferred)	[52]
T1548.002	Bypass User Account Control	privilege-escalation	Listed	S0606	[26]
T1036	Masquerading	stealth	Listed	S0368	[87]
T1036.005	Match Legitimate Resource Name or Location	stealth	Listed	S0606; C0030	[26][89]
T1218.011	Rundll32	stealth	Listed	S0368; S0606	[87][26]
T1574.001	DLL	stealth, execution	Described	PlugX and RedLeaves launched by DLL side-loading at service providers (TA17-117A; revoked T1574.002 maps here)	[88][26]
T1221	Template Injection	stealth	Described	Dragonfly 2.0 spear-phishing with Phishery template injection (Symantec); TA18-074A; the library maps it to G0035	[33][52][26]
T1027.005	Indicator Removal from Tools	stealth	Listed	C0030	[89]
T1686	Disable or Modify System Firewall	defense-impairment	Described	Firewall disabled (TA17-293A); the library maps it to G0035	[34][26]
T1070	Indicator Removal	stealth	Described	Equifax intruders wiped logs daily (DOJ allegation)	[55]
T1685.005	Clear Windows Event Logs	defense-impairment	Listed	S0368 (see Discrepancies); log deletion in TA17-293A (Described); the library maps it to G0035	[87][34][26]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1553.002	Code Signing	defense-impairment	Inferred	CCleaner 5.33 signed with a valid Piriform certificate (Talos); NetSarang installers signed with NetSarang's certificate (Kaspersky)	[29][28]
T1003.001	LSASS Memory	credential-access	Listed	NotPetya's modified Mimikatz (S0368; TA17-181A); S0606; C0030; XData's embedded Mimikatz (ESET, Described)	[87][18][26][89][17]
T1110.002	Password Cracking	credential-access	Described	Hashes leaked by forced SMB authentication cracked (TA17-293A; TA18-074A)	[34][52]
T1110.003	Password Spraying	credential-access	Listed	S0606	[26]
T1187	Forced Authentication	credential-access	Described	Word documents and .LNK files that force SMB authentication (TA17-293A); the library maps it to G0035	[34][52][26]
T1056.003	Web Portal Capture	collection, credential-access	Listed	C0030	[89]
T1552.001	Credentials In Files	credential-access	Inferred	Equifax: unencrypted credentials used to reach 48 more databases (GAO); administrative credentials in plain text (FTC)	[13][14]
T1518.001	Security Software Discovery	discovery	Listed	S0368	[87]
T1083	File and Directory Discovery	discovery	Listed	S0368; file servers searched for ICS and SCADA documents (TA17-293A, Described)	[87][34]
T1135	Network Share Discovery	discovery	Listed	S0606	[26]
T1057	Process Discovery	discovery	Listed	S0606	[26]
T1210	Exploitation of Remote Services	lateral-movement	Listed	MS17-010 exploits: WannaCry, 12 May (S0366; TA17-132A); NotPetya, 27 Jun (S0368; TA17-181A); Bad Rabbit, 24 Oct (S0606)	[85][15][87][18][26]
T1021.002	SMB/Windows Admin Shares	lateral-movement	Listed	NotPetya with PsExec and stolen credentials (S0368; TA17-181A)	[87][18]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1570	Lateral Tool Transfer	lateral-movement	Listed	S0366	[85]
T1563.002	RDP Hijacking	lateral-movement	Listed	S0366	[85]
T1113	Screen Capture	collection	Described	Screenshots taken (TA17-293A); the library maps it to G0035	[34][26]
T1213	Data from Information Repositories	collection	Inferred	About 9,000 queries across Equifax databases (GAO)	[13]
T1530	Data from Cloud Storage	collection	Inferred	Uber files downloaded from a third-party cloud provider (FTC)	[40]
T1090.003	Multi-hop Proxy	command-and-control	Listed	S0366; Equifax traffic routed through about 34 servers in nearly 20 countries (DOJ allegation, Inferred)	[85][55]
T1573	Encrypted Channel	command-and-control	Listed	C0030; Equifax data removed over standard encrypted web protocols (GAO, Inferred)	[89][13]
T1573.001	Symmetric Cryptography	command-and-control	Described	RC4-encrypted command traffic over port 443 (TA17-117A)	[88]
T1030	Data Transfer Size Limits	exfiltration	Inferred	Equifax data removed in small increments (GAO)	[13]
T1485	Data Destruction	impact	Described	The second Shamoon 2 wave set to wipe on 29 Nov 2016 (Unit 42, 9 Jan 2017)	[1]
T1486	Data Encrypted for Impact	impact	Listed	S0366 WannaCry; S0368 NotPetya; S0606 Bad Rabbit; S0370 SamSam	[85][87][26][65]
T1489	Service Stop	impact	Listed	S0366	[85]
T1490	Inhibit System Recovery	impact	Listed	S0366	[85]
T1495	Firmware Corruption	impact	Listed	S0606	[26]
T1498	Network Denial of Service	impact	Inferred	HIDDEN COBRA's DDoS botnet and DeltaCharlie (TA17-164A, 13 Jun 2017)	[24]
T1529	System Shutdown/Reboot	impact	Listed	S0368	[87]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1561.002	Disk Structure Wipe	impact	Described	NotPetya modifies the master boot record, leaving machines unusable (TA17-181A)	[18]

Not mapped, because no source opened prints or describes the behavior closely enough to choose an id: WannaCry's kill-switch check (the advisory describes it, but this study does not assign a technique), the Yahoo and AlphaBay records, Cloudbleed and KRACK, the Mirai and Kelihos botnets as operated in 2017, and the En Marche leak stage [15][53][67][2][35][69][66][48].

ATT&CK for ICS techniques

The ATT&CK record of Triton is split across two objects: the campaign C0030 maps the operator's moves, and the software page S1009 maps what the framework does to the controller (Confirmed [89][90]). A layer built from C0030 alone would leave out Loss of Safety (Inferred [89][90]). WannaCry and NotPetya also carry ICS rows on their software pages (Confirmed [85][87]). Mandiant's own account supports Program Download, Modify Controller Tasking and Loss of Safety directly (Confirmed for the behavior [25]). The library has no generated ICS technique pages, so these ids link to attack.mitre.org; each was checked in `data/attack/ics/technique_profiles.jsonl` [26].

Id	Name (ATT&CK for ICS v20.0)	Tactic(s)	Basis	Where it appears	Sources
T0880	Loss of Safety	impact	Listed	S1009 Triton; safety controllers trip and shut the process down (Mandiant, 14 Dec 2017)	[90][25]
T0858	Change Operating Mode	execution, evasion	Listed	S1009; the key switch must be in PROGRAM (ICSA-18-107-02)	[90][91]
T0821	Modify Controller Tasking	execution	Listed	S1009; reprogramming over TriStation (Mandiant)	[90][25]
T0843	Program Download	lateral-movement	Listed	S1009; Mandiant	[90][25]
T0843.003	Program Append	lateral-movement	Listed	C0030	[89]
T0845	Program Upload	collection	Listed	S1009	[90]
T1693.001	System Firmware	persistence, inhibit-response-function, impair-process-control	Listed	S1009	[90]
T0820	Exploitation for Evasion	evasion	Listed	S1009	[90]
T0890	Exploitation for Privilege Escalation	privilege-escalation	Listed	S1009; the Tricon firmware flaws found during the HatMan investigation (ICSA-18-107-02)	[90][91]
T0874	Hooking	execution, privilege-escalation	Listed	S1009	[90]

Id	Name (ATT&CK for ICS v20.0)	Tactic(s)	Basis	Where it appears	Sources
T0872	Indicator Removal on Host	evasion	Listed	S1009; C0030	[90][89]
T0849	Masquerading	evasion	Listed	S1009	[90]
T0868	Detect Operating Mode	collection	Listed	S1009	[90]
T0871	Execution through API	execution	Listed	S1009	[90]
T0834	Native API	execution	Listed	S1009	[90]
T0846.002	Broadcast Discovery	discovery	Listed	S1009	[90]
T0885	Commonly Used Port	command-and-control	Listed	S1009	[90]
T0869	Standard Application Layer Protocol	command-and-control	Listed	S1009	[90]
T1701	Command and Scripting Interpreter	execution	Listed	C0030	[89]
T1701.001	PowerShell	execution	Listed	C0030	[89]
T1701.005	Python	execution	Listed	S1009	[90]
T0830	Adversary-in-the-Middle	collection	Listed	C0030	[89]
T1692.001	Command Message	evasion, impair-process-control	Listed	C0030	[89]
T0886	Remote Services	initial-access, lateral-movement	Listed	C0030	[89]
T0859	Valid Accounts	persistence, lateral-movement	Listed	C0030	[89]
T0867	Lateral Tool Transfer	lateral-movement	Listed	C0030; S0366; S0368	[89][85][87]
T0866	Exploitation of Remote Services	initial-access, lateral-movement	Listed	S0366 WannaCry; S0368 NotPetya	[85][87]
T0828	Loss of Productivity and Revenue	impact	Listed	C0030; S0368 NotPetya (the Merck and FedEx filings describe the effect)	[89][87][19][20]

ATT&CK also maps T0817 Drive-by Compromise and T0862 Supply Chain Compromise to G0088 TEMP.Veles at group level in the library's ICS data; neither is dated to 2017, so neither is a row above or in the ICS layer (Confirmed [26]).

ATT&CK groups, software and campaigns

Groups (every page exists under `/mitre/groups/`):

Id	Group (library name)	The 2017 tie	Grade	Sources
G0032	Lazarus Group (aliases include HIDDEN COBRA)	WannaCry user per S0366; UK attribution of WannaCry to the Lazarus Group; DOJ complaint; HIDDEN COBRA alerts	Confirmed	[85][44][45][24]

Id	Group (library name)	The 2017 tie	Grade	Sources
G0034	Sandworm Team (aliases include Telebots, Voodoo Bear, IRON VIKING)	NotPetya user per S0368; GRU Unit 74455 indictment; ESET's TeleBots link for XData and NotPetya (Reported)	Confirmed	[87][48][17]
G0035	Dragonfly	TA17-293A cites Symantec's Dragonfly report; DOJ's "Dragonfly 2.0" phase	Confirmed	[34][33][51]
G0045	menuPass (alias APT10)	Cloud Hopper and the MSP Theft Campaign	Confirmed	[8][54][88]
G0088	TEMP.Veles	C0030	Confirmed	[89]
G0022	APT3	Third-party attribution to the MSS (May 2017); the link to the Boyusec indictment is not made by DOJ	Reported	[57][56]
G0064	APT33	Named by Mandiant, 20 Sep 2017	Reported	[58]
G0049	OilRig (alias APT34)	CVE-2017-11882 exploitation, Dec 2017	Reported	[59]
G0050	APT32 (alias OceanLotus)	FireEye, May 2017	Reported	[60]
G0020	Equation	Kaspersky's November 2017 account of its 2014 Equation detection (the group tie is Inferred)	Inferred	[38]

Not mapped, because no source opened ties the activity to an ATT&CK group: the Yahoo defendants, the Boyusec defendants as a group, the PLA members charged over Equifax, the Shamoon 2 operator in Unit 42's report, the NetSarang and CCleaner operators in the 2017 reports, the SamSam defendants, and the Shadow Brokers [53][56][55][1][28][29][65][9].

Software (pages exist under `/mitre/software/` except where noted):

Id	Software	The 2017 tie	Sources
S0366	WannaCry	12 May 2017	[15][85]
S0368	NotPetya (aliases include Diskcoder.C, Nyetya)	27 Jun 2017	[18][87]
S0606	Bad Rabbit	24 Oct 2017	[36][37][26]
S0370	SamSam (alias Samas)	December 2015 to 2018 scheme	[65][26]
S1074	ANDROMEDA	Andromeda (Gamarue) takedown, 29 Nov 2017	[70][26]
S0140	Shamoon (alias Disttrack)	Second Shamoon 2 wave, reported 9 Jan 2017	[1]
S0596	ShadowPad	NetSarang, Jul to Aug 2017	[28]
S0181	FALLCHILL	TA17-318A, 14 Nov 2017	[46]
S0180	Volgmer	TA17-318B, 14 Nov 2017 (id checked in the library's data)	[47][26]
S0013	PlugX	TA17-117A, 27 Apr 2017 (id checked in the library's data)	[88][26]
S0153	RedLeaves	TA17-117A (id checked in the library's data)	[88][26]

Id	Software	The 2017 tie	Sources
S0002	Mimikatz	C0030; NotPetya's modified Mimikatz; XData; Bad Rabbit	[89][18][17][36]
S0029	PsExec	NotPetya and XData lateral movement	[18][17][26]
S0604	Industroyer (alias CRASHOVERRIDE)	Reported 12 Jun 2017 for the 2016 attack	[49][79]
S1009	Triton (aliases TRISIS, HatMan; ICS; no library page)	C0030	[90][89][26]

The library has no `/mitre/software/S1009.md` page; S1009 appears only in `data/attack/ics/software.jsonl`. ATT&CK's G0088 text links TRITON as S0609, an id absent from the library's data, so this study uses S1009 (Confirmed [26]). Not linked, because no ATT&CK software object for them was checked: DeltaCharlie, XData, the CCleaner backdoor, Mirai and Kelihos [24][17][29][69][66].

Campaigns (pages exist under `/mitre/campaigns/`):

Id	Campaign	Window in library data	The 2017 tie	Sources
C0030	Triton Safety Instrumented System Attack	2017-06 to 2017-08	The Triton intrusion (Part 7)	[89][26]
C0006	Operation Honeybee	2017-08 to 2018-02	Window spans 2017; not opened for this study	[26]
C0013	Operation Sharpshooter	2017-09 to 2019-03	Window spans 2017; not opened for this study	[26]
C0014	Operation Wocao	2017-12 to 2019-12	Window spans 2017; not opened for this study	[26]
C0023	Operation Ghost	2013-09 to 2019-10	Window spans 2017; not opened for this study	[26]
C0032	C0032	2014-10 to 2017-01	Window ends in January 2017; not opened for this study	[26]
C0033	C0033	2016-05 to 2023-01	Window spans 2017; not opened for this study	[26]

Only C0030 contributes techniques to the tables above; the other six are listed so a reader can find ATT&CK's 2017-era campaign objects, and their technique rows were not checked against a 2017 event (Confirmed for the windows [26]). The library's data has no campaign object for WannaCry, NotPetya, Bad Rabbit, Cloud Hopper, Equifax or the 2017 Dragonfly activity (Confirmed [26]).

CWE and CAPEC

The CWE ids are those NVD, KEV or the ICS advisory list for each CVE (Confirmed [7][75][76][5][91]). The CAPEC column lists the attack patterns the library's `cwe.jsonl` relates to that CWE, linked where a generated page exists; choosing the closest pattern is this study's reading (Inferred [26]).

CWE	Weakness (library name)	CVEs from the 2017 record	CAPEC the library relates
CWE-755	Improper Handling of Exceptional Conditions	CVE-2017-5638 Struts (NVD and CNA)	none in library data
CWE-20	Improper Input Validation	KEV's CWE for CVE-2017-0143 to 0146, 0148 and CVE-2017-5638	broad class with 51 related patterns; none chosen

CWE	Weakness (library name)	CVEs from the 2017 record	CAPEC the library relates
CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	CVE-2017-11882 (NVD); CVE-2018-8872 and CVE-2018-7522 in Tricon (ICSA-18-107-02)	CAPEC-100 Overflow Buffers (the library also relates CAPEC-10, 14, 24, 42 and others)
CWE-94	Improper Control of Generation of Code	CVE-2017-8759 (NVD)	CAPEC-242 Code Injection (the library also relates CAPEC-35 and CAPEC-77)
CWE-494	Download of Code Without Integrity Check	M.E.Doc, NetSarang and CCleaner updates (binding Inferred; no source states a CWE)	CAPEC-186 Malicious Software Update and CAPEC-187 Malicious Automated Software Update via Redirection

NVD lists NVD-CWE-noinfo for CVE-2017-0144, CVE-2017-0145 and CVE-2017-0199, which the table does not bind (Confirmed [76][75]). KEV and NVD disagree for the MS17-010 family and for Struts (see Discrepancies).

The library's CAPEC records tie several patterns to techniques in the Enterprise table, and the 2017 record supplies an event for each (bindings Inferred [26]): CAPEC-186 Malicious Software Update (T1195.002) for M.E.Doc and CCleaner; CAPEC-187 Malicious Automated Software Update via Redirection (the library maps it to T1072, not used here) for M.E.Doc's update requests proxied to an outside host [86]; CAPEC-206 Signing Malicious Code (T1553.002) for CCleaner 5.33 [29]; CAPEC-511 Infiltration of Software Development Environment (T1195.001 in the library, a technique this study does not map) for the backdoor in M.E.Doc's development environment [18]; CAPEC-561 Windows Admin Shares with Stolen Credentials (T1021.002) for NotPetya [18]; CAPEC-555 Remote Services with Stolen Credentials (T1133) for Dragonfly's VPN, RDP and OWA logons [34]; CAPEC-560 Use of Known Domain Credentials (T1078) for the service-provider intrusions [88]; and CAPEC-163 Spear Phishing (T1566.001) for the Dragonfly campaign [34].

D3FEND countermeasures

Pairings come from `data/attack/technique_to_d3fend.jsonl`; every page exists under `/mitre/d3fend/` [26]. The pairings are Confirmed as library data; matching each to an advisory control is this study's reading (Inferred).

Technique from the record	D3FEND countermeasures the library maps	The 2017 control it matches
T1210 Exploitation of Remote Services	Network Traffic Filtering, Network Traffic Signature Analysis	SMB blocked at the boundary and between workstations [15][18][16]
T1490 Inhibit System Recovery, T1195.002 Compromise Software Supply Chain	Software Update, Software Inventory, Restore Software, Asset Vulnerability Enumeration; T1490 also Restore Configuration	MS17-010 and SMBv1 removal; CCleaner restore to before 15 Aug [4][15][29]
T1486 Data Encrypted for Impact	Restore File, File Integrity Monitoring, Decoy File	Tested backups off the local network [15][18]
T1003.001 LSASS Memory	Process Lineage Analysis, Process Spawn Analysis, Application-based Process Isolation	NotPetya's credential theft [18]

Technique from the record	D3FEND countermeasures the library maps	The 2017 control it matches
T1047 Windows Management Instrumentation	Administrative Network Activity Analysis, Executable Allowlisting, Network Traffic Filtering	Limit remote WMI and authorize WMI users [18]
T1110.002 Password Cracking	Multi-factor Authentication, Credential Rotation, Credential Hardening	MFA and credential resets [34]
T1136.001 Local Account	Local Account Monitoring, Account Locking	Hunt new administrator accounts [34]
T1133 External Remote Services	Session Termination (the only pairing)	Single-factor VPN, RDP and OWA; MFA is the advisory's control, not a library pairing for T1133 [34]
T1199 Trusted Relationship	User Geolocation Logon Pattern Analysis, Network Traffic Community Deviation	Providers watch bandwidth anomalies; customers validate providers [88]
T1566.001 Spearphishing Attachment, T1187 Forced Authentication	Email Filtering (T1566.001), File Analysis, Content Filtering	Dragonfly's documents that force SMB authentication; SMB egress blocked [34]
T1190 Exploit Public-Facing Application	Inbound Traffic Filtering, Database Query String Analysis, Inbound Session Volume Analysis	Equifax's dispute portal and the unlimited query rate [13]
T1030 Data Transfer Size Limits	Per Host Download-Upload Ratio Analysis	Equifax's small-increment removal over uninspected encrypted traffic [13]
T1078 Valid Accounts	User Account Permissions, Account Locking	Least privilege at service providers [88]
T1561.002 Disk Structure Wipe	Disk Partitioning (the only pairing)	NotPetya's MBR change; offline backups are the advisory's control [18]

The library data has no D3FEND mapping for T1021.002 SMB/Windows Admin Shares, T1529 System Shutdown/Reboot, T1485 Data Destruction, T1569.002 Service Execution, T1530 Data from Cloud Storage, T1595.002 Vulnerability Scanning, T1221 Template Injection, T1553.002 Code Signing or T1685.005 Clear Windows Event Logs; none is invented here [26].

Navigator layers

The study's techniques are saved as two ATT&CK Navigator layers pinned to ATT&CK v20: the Enterprise layer navigator/library-layers/chronicle-2017.json (the 68 techniques of the Enterprise table) and the ICS layer navigator/case-studies/chronicle-2017-ics.json (the 28 techniques of the ICS table), both listed on the Navigator layers page. Scores show the basis, not severity: 100 where the source or ATT&CK object prints the id (Listed), 70 where the source describes the behavior and this study assigns the id (Described), 50 where only a Reported source supports it, and 40 for an Inferred mapping. The Described score of 70 follows the 2019 and 2021 studies in this series; the 2020 study scores the same basis at 75. Each entry's comment names the source numbers in the Sources table below, and each technique is shown under every tactic it has in v20.0.

Cross-cutting themes

Leaked tools became everyone's tools. The exploits the Shadow Brokers made public in April were fixed in March (Confirmed [9][4]), and by June they were inside two worms attributed to two different states (Confirmed [15][18][41][21]). A leak turns a state capability into a commodity within weeks (Inferred). The US Vulnerabilities Equities charter followed in November (Confirmed [84]).

Destruction wore a ransom note. WannaCry, NotPetya and Bad Rabbit all looked like ransomware (Confirmed [15][18][37]). NotPetya's victims could not buy their data back (Confirmed [18]), and ATT&CK classes it as a wiper (Confirmed [87]). Counting it among ransomware incidents misstates both the motive and the right response (Inferred).

Trust in the channel, not the sender. M.E.Doc's update server, CCleaner's signed installer, NetSarang's signed packages and IT service providers all delivered attacker code or access through a channel the victim had reason to trust (Confirmed [86][29][88]; Reported for NetSarang's signing [28]). The SolarWinds study shows the same pattern three years later (Inferred).

Safety was attacked through engineering access. Triton came through an SIS engineering workstation and depended on the controller's programming mode (Confirmed [25][91]). The defense is procedural (key switch, change management) as much as technical (Inferred from [25][91]).

Costs moved into filings. FedEx reported NotPetya, and Merck a 27 June network cyber-attack, in their SEC filings within months (Confirmed [19][20]; the Merck tie Inferred); Equifax announced its breach by 8-K (Confirmed [10]). IC3's complaint totals, by contrast, put ransomware losses at a few million dollars (Confirmed [71]). The public cost record of 2017 is in securities filings, not crime statistics (Inferred).

The rulebook moved from frameworks to directives. EO 13800 told agencies to use the NIST Framework, BOD 17-01 told them to remove named products, and NYDFS put cybersecurity rules on a regulated sector (Confirmed [80][31][81]).

What is overstated and what is understated

This section is the study's reading of the record (Inferred).

- **Overstated: NotPetya as ransomware.** TA17-181A says it behaves as destructive malware and ATT&CK calls it a wiper [18][87].
- **Overstated: Equifax as a single missed patch.** GAO lists four factors plus an expired inspection certificate, a stale alert list and a scan that missed the portal [13].
- **Overstated: "2017 KEV additions".** KEV did not exist in 2017; every 2017 CVE in it was added from November 2021 onward [5].
- **Overstated: the Shadow Brokers' whole release as live risk.** Of the exploits MSRC triaged, the SMB set was already fixed and three did not reproduce on supported platforms; the danger was the unpatched estate, not new flaws [9][16].
- **Overstated: attribution at the time of the event.** No 2017 primary record opened here attributes NotPetya, Triton or Cloud Hopper to a state; those statements date from 2018 to 2021, and Mandiant's 2017 Triton view was "moderate confidence" [21][50][8][25].

- **Overstated: one number for WannaCry's reach.** US-CERT says tens of thousands, the White House hundreds of thousands, the UK 300,000 [15][41][44].
- **Understated: credential theft and single-factor remote access as the common thread.** NotPetya, Dragonfly, the MSP intrusions and Equifax all moved on stolen or stored credentials [18][34][88][13].
- **Understated: luck in detection.** The WannaCry kill switch, the Triton safety trip and Equifax's certificate renewal each exposed an attack that defenses had not stopped [16][89][13].
- **Understated: the release-day flag.** CVE-2017-0199, CVE-2017-11882 and the MS17-010 family were "Exploited: No" at release and are now in KEV with known ransomware use [72][73][5].
- **Understated: email fraud.** IC3's business email compromise losses were nearly 300 times its ransomware losses in 2017 [71].
- **Understated: the ATT&CK record of Triton.** C0030 alone omits the safety-impact techniques that sit on S1009 [89][90].

Discrepancies in the record

- **WannaCry's reach.** Tens of thousands of infections in over 150 countries (US-CERT); hundreds of thousands of computers in over 150 countries (White House); 300,000 computers in 150 countries (UK) [15][41][44].
- **NHS counts.** The NAO counts at least 81 of 236 trusts disrupted; the UK Foreign Office says 48 NHS trusts were hit [16][44].
- **The legacy-platform updates.** The MSRC guidance is dated 12 May; US-CERT dates the XP, Windows 8 and Server 2003 patches to 13 May [62][15].
- **Equifax counts.** About 143 million (8-K), at least 145.5 million (GAO), about 145 million (DOJ), about 147 million (FTC) [10][13][55][14].
- **Uber counts.** Uber gives 57 million users and about 600,000 driver's licenses; the FTC gives more than 25 million names and emails, 22 million names and phone numbers and 600,000 licenses [39][40].
- **Dragonfly's start date.** TA17-293A says since at least May 2017; TA18-074A since at least March 2016; Symantec's earliest activity December 2015; DOJ dates the wider campaign 2012 to 2017 [34][52][33][51].
- **Symantec's report date.** TA17-293A cites Symantec's Dragonfly report of 6 September 2017; the page opened shows 20 October 2017, and whether that is the original publication date was not checked [34][33].
- **Triton's window.** ATT&CK C0030 gives June to August 2017; the DOJ indictment alleges May to September 2017; Treasury dates the attack to August 2017 [89][51][50].
- **Triton's id.** ATT&CK's G0088 text links TRITON as S0609, absent from the library's data; the library and this study use S1009 [26].
- **NotPetya's ATT&CK record.** S0368 lists T1685.005 Clear Windows Event Logs, which TA17-181A does not mention, and omits T1195.002, although TA17-181A names M.E.Doc as delivery and the library maps T1195.002 to G0034 at group level [87][18][26].
- **CWE for the year's flagship CVEs.** KEV lists CWE-20 for CVE-2017-0143 to 0146, 0148 and CVE-2017-5638; NVD lists NVD-CWE-noinfo for the MS17-010 CVEs it records and CWE-755 for Struts [5][76][7].

- **Release-day exploitation.** Microsoft marked CVE-2017-0199 and the MS17-010 CVEs "Exploited: No"; Project Zero lists CVE-2017-0199 and CVE-2017-0143 to 0147 as 2017 in-the-wild zero-days [72][73][74].
- **Where the leaked tools came from.** That WannaCry used exploits stolen from the NSA is Microsoft's statement, and that Vault 7 came from the CIA is WikiLeaks' claim; no government record opened for this study states either [63][3].
- **Merck and Nuance.** Merck's 10-Q describes a 27 June 2017 network cyber-attack and Nuance's 8-K a 27 June 2017 malware incident, and neither names NotPetya; both ties rest on the date and are Inferred [19][64][43].
- **The Mirai plea date.** This study dates the guilty pleas to 8 December 2017 from the DOJ announcement of 13 December [69]; the Fancy Bear Goes Phishing cases study dates the filing of the informations and plea agreements in the District of Alaska to 5 December 2017. A filing date and a plea date can differ; the DOJ release could not be reopened during this revision (justice.gov served an empty page and the Internet Archive refused the request), so which date the court record gives for the pleas was not checked.
- **ATT&CK versions.** The live site showed content v20.1 on S1009 and S0366; the library and this study's names and tactics are v20.0 [90][85][26].

Sources

All sources were opened on 11 November 2026. Grade is the source's evidence grade as used in this study. Pages read from an Internet Archive snapshot are noted in Scope and method. Addresses shown as code rather than as links refuse automated link checkers: the sec.gov filings and the SEC press release, the GAO report pages, the FTC releases and Uber's newsroom statement; copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	Palo Alto Networks Unit 42, Second Wave of Shamoon 2 Attacks Identified, 9 Jan 2017	unit42.paloaltonetworks.com	2026-11-11	Confirmed
2	Cloudflare, Incident report on memory leak caused by Cloudflare parser bug, 23 Feb 2017	blog.cloudflare.com	2026-11-11	Confirmed
3	WikiLeaks, Vault 7 Part 1, "Year Zero", 7 Mar 2017 (publication only; provenance is WikiLeaks' claim)	wikileaks.org	2026-11-11	Confirmed
4	Microsoft, Security Bulletin MS17-010, 14 Mar 2017	learn.microsoft.com	2026-11-11	Confirmed
5	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10	cisa.gov	2026-11-11	Confirmed
6	Apache Struts, security bulletin S2-045 (CVE-2017-5638), last updated 19 Mar 2017	cwiki.apache.org	2026-11-11	Confirmed
7	NIST NVD, CVE-2017-5638 record (API 2.0)	services.nvd.nist.gov	2026-11-11	Confirmed
8	UK Government, UK and allies reveal global scale of Chinese cyber campaign, 20 Dec 2018	gov.uk	2026-11-11	Confirmed
9	Microsoft MSRC, Protecting customers and evaluating risk, 15 Apr 2017, updated 13 Jun 2017	microsoft.com	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
10	Equifax, Form 8-K exhibit 99.1, 7 Sep 2017	https://www.sec.gov/Archives/edgar/data/33185/000003318517000026/exhibit99120170907.htm	2026-11-11	Confirmed
11	Equifax, correspondence with the SEC, 14 Aug 2018	https://www.sec.gov/Archives/edgar/data/33185/000003318518000029/filename1.htm	2026-11-11	Confirmed
12	US GAO, GAO-18-559, Data Protection: Actions Taken by Equifax and Federal Agencies in Response to the 2017 Breach, product page (published 30 Aug 2018, released 7 Sep 2018)	https://www.gao.gov/products/gao-18-559	2026-11-11	Confirmed
13	US GAO, GAO-18-559, full report (PDF)	https://www.gao.gov/assets/gao-18-559.pdf	2026-11-11	Confirmed
14	US FTC, Equifax to pay $575 million as part of settlement with FTC, CFPB, and states, 22 Jul 2019	https://www.ftc.gov/news-events/news/press-releases/2019/07/equifax-pay-575-million-part-settlement-ftc-cfpb-states-related-2017-data-breach	2026-11-11	Confirmed
15	CISA (US-CERT), TA17-132A, Indicators Associated With WannaCry Ransomware, 12 May 2017, revised to 7 Jun 2018	cisa.gov	2026-11-11	Confirmed
16	UK National Audit Office, Investigation: WannaCry cyber attack and the NHS, 27 Oct 2017	nao.org.uk	2026-11-11	Confirmed
17	ESET WeLiveSecurity, TeleBots are back: supply-chain attacks against Ukraine, 30 Jun 2017	welivesecurity.com	2026-11-11	Confirmed (findings); Reported (actor link)
18	CISA (US-CERT), TA17-181A, Petya Ransomware, 1 Jul 2017, revised to 15 Feb 2018	cisa.gov	2026-11-11	Confirmed
19	Merck & Co., Form 10-Q for the quarter ended 30 Sep 2017, filed 7 Nov 2017	https://www.sec.gov/Archives/edgar/data/310158/000031015817000045/mrk0930201710q.htm	2026-11-11	Confirmed
20	FedEx, Form 8-K exhibit 99.1, first-quarter FY2018 results, 19 Sep 2017	https://www.sec.gov/Archives/edgar/data/1048911/000119312517288350/d447254dex991.htm	2026-11-11	Confirmed
21	The White House (archive), Statement from the Press Secretary on NotPetya, 15 Feb 2018	trumpwhitehouse.archives.gov	2026-11-11	Confirmed
22	UK Government, Foreign Office Minister condemns Russia for NotPetya attacks, 15 Feb 2018	gov.uk	2026-11-11	Confirmed
23	US Treasury, press release sm0312, sanctions on Russian cyber actors, 15 Mar 2018	home.treasury.gov	2026-11-11	Confirmed
24	CISA (US-CERT), TA17-164A, HIDDEN COBRA: North Korea's DDoS Botnet Infrastructure, 13 Jun 2017	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
25	Mandiant (then FireEye), Attackers Deploy New ICS Attack Framework "TRITON", 14 Dec 2017	cloud.google.com	2026-11-11	Confirmed (findings); Reported (attribution assessment)
26	TeamStarWolf library, main branch: `data/attack/` (campaigns, campaign profiles, groups, software, ICS software, software and group technique maps, technique profiles, ICS technique profiles, technique_to_d3fend, superseded_by), `data/weaknesses/` (cwe, capec) and the `mitre/` tree	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Confirmed
27	TeamStarWolf library, `case-studies/` on main (coverage of 2017 events in the home studies)	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Confirmed
28	Kaspersky Securelist, ShadowPad in corporate networks, 15 Aug 2017	securelist.com	2026-11-11	Confirmed
29	Cisco Talos, CCleanup: A Vast Number of Machines at Risk, 18 Sep 2017	blog.talosintelligence.com	2026-11-11	Confirmed
30	Avast, Update to the CCleaner 5.33.6162 security incident, 19 Sep 2017	blog.avast.com	2026-11-11	Confirmed
31	CISA, BOD 17-01, Removal of Kaspersky-branded Products, 13 Sep 2017	cisa.gov	2026-11-11	Confirmed
32	Verizon, Form 8-K exhibit 99.1 (Yahoo and Oath account notice), 3 Oct 2017	`https://www.sec.gov/Archives/edgar/data/732712/000073271217000003/a2017_10x3xoathxexhibitx991.htm`	2026-11-11	Confirmed
33	Symantec (security.com), Dragonfly: Western energy sector targeted by sophisticated attack group (page shows 20 Oct 2017)	security.com	2026-11-11	Confirmed (findings); Reported (possible access to operational systems)
34	CISA (US-CERT), TA17-293A, Advanced Persistent Threat Activity Targeting Energy and Other Critical Infrastructure Sectors, 20 Oct 2017	cisa.gov	2026-11-11	Confirmed
35	CERT/CC, VU#228519, WPA2 key reinstallation (KRACK), 16 Oct 2017	kb.cert.org	2026-11-11	Confirmed
36	ESET WeLiveSecurity, Bad Rabbit: Not-Petya is back with improved ransomware, 24 Oct 2017	welivesecurity.com	2026-11-11	Confirmed
37	CISA (US-CERT), Multiple Ransomware Infections Reported, 24 Oct 2017	cisa.gov	2026-11-11	Confirmed
38	Kaspersky Securelist, Investigation report for the September 2014 Equation malware detection incident in the US, 16 Nov 2017	securelist.com	2026-11-11	Confirmed (the vendor's own account)
39	Uber Newsroom, 2016 Data Security Incident, statement of 21 Nov 2017	`https://www.uber.com/newsroom/2016-data-incident/`	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
40	US FTC, Uber agrees to expanded settlement with FTC related to privacy, security claims, 12 Apr 2018	`https://www.ftc.gov/news-events/news/press-releases/2018/04/uber-agrees-expanded-settlement-ftc-related-privacy-security-claims`	2026-11-11	Confirmed
41	The White House (archive), Press briefing on the attribution of the WannaCry malware attack to North Korea, 19 Dec 2017	trumpwhitehouse.archives.gov	2026-11-11	Confirmed
42	US Treasury, press release sm473, designation of Park Jin Hyok and Chosun Expo Joint Venture, 6 Sep 2018	home.treasury.gov	2026-11-11	Confirmed
43	SEC EDGAR full-text search, "NotPetya", 27 Jun to 31 Dec 2017 (results list only; Nuance filings not opened in full)	efts.sec.gov	2026-11-11	Inferred
44	UK Government, Foreign Office Minister condemns North Korean actor for WannaCry attacks, 19 Dec 2017	gov.uk	2026-11-11	Confirmed
45	US DOJ, North Korean regime-backed programmer charged with conspiracy to conduct multiple cyber attacks and intrusions, 6 Sep 2018	justice.gov	2026-11-11	Confirmed (allegations)
46	CISA (US-CERT), TA17-318A, HIDDEN COBRA: North Korean Remote Administration Tool FALLCHILL, 14 Nov 2017	cisa.gov	2026-11-11	Confirmed
47	CISA (US-CERT), TA17-318B, HIDDEN COBRA: North Korean Trojan Volgmer, 14 Nov 2017	cisa.gov	2026-11-11	Confirmed
48	US DOJ, Six Russian GRU officers charged in connection with worldwide deployment of destructive malware, 19 Oct 2020	justice.gov	2026-11-11	Confirmed (allegations)
49	ESET WeLiveSecurity, Industroyer: biggest threat to industrial control systems since Stuxnet, 12 Jun 2017	welivesecurity.com	2026-11-11	Reported
50	US Treasury, press release sm1162, designation of TsNIIKhM	home.treasury.gov	2026-11-11	Confirmed
51	US DOJ, Four Russian government employees charged in two historical hacking campaigns targeting critical infrastructure worldwide	justice.gov	2026-11-11	Confirmed (allegations)
52	CISA (US-CERT), TA18-074A, Russian Government Cyber Activity Targeting Energy and Other Critical Infrastructure Sectors, 15 Mar 2018	cisa.gov	2026-11-11	Confirmed
53	US DOJ, U.S. charges Russian FSB officers and their criminal conspirators for hacking Yahoo and millions of email accounts, 15 Mar 2017	justice.gov	2026-11-11	Confirmed (allegations)

#	Source	URL	Opened	Grade
54	US DOJ, Two Chinese hackers associated with the Ministry of State Security charged with global computer intrusion campaigns, 20 Dec 2018	justice.gov	2026-11-11	Confirmed (allegations)
55	US DOJ, Chinese military personnel charged with computer fraud, economic espionage and wire fraud for hacking into credit reporting agency Equifax, 10 Feb 2020	justice.gov	2026-11-11	Confirmed (allegations)
56	US DOJ, U.S. charges three Chinese hackers who work at internet security firm for hacking three corporations, 27 Nov 2017	justice.gov	2026-11-11	Confirmed (allegations)
57	MITRE ATT&CK, group G0022 APT3	attack.mitre.org	2026-11-11	Reported (third-party attribution it relays)
58	Mandiant (then FireEye), Insights into Iranian cyber espionage: APT33 targets aerospace and energy sectors, 20 Sep 2017	cloud.google.com	2026-11-11	Reported
59	Mandiant (then FireEye), New targeted attack in the Middle East by APT34, 7 Dec 2017	cloud.google.com	2026-11-11	Reported
60	Mandiant (then FireEye), Cyber espionage is alive and well: APT32 and the threat to global corporations, May 2017	cloud.google.com	2026-11-11	Reported
61	DHS, DHS statement on the issuance of Binding Operational Directive 17-01, 13 Sep 2017	dhs.gov	2026-11-11	Confirmed
62	Microsoft MSRC, Customer Guidance for WannaCrypt attacks, 12 May 2017 (Internet Archive 2017 snapshot)	blogs.technet.microsoft.com	2026-11-11	Confirmed
63	Microsoft On the Issues, The need for urgent collective action to keep people safe online, 14 May 2017	blogs.microsoft.com	2026-11-11	Reported (Microsoft's claim on the exploits' origin)
64	Nuance Communications, Form 8-K exhibit 99.1, 8 Aug 2017	`https://www.sec.gov/Archives/edgar/data/1002517/000100251717000021/ex991pressreleasejune302017.htm`	2026-11-11	Confirmed (filing); Inferred (NotPetya link)
65	US DOJ, Two Iranian men indicted for deploying ransomware to extort hospitals, municipalities, and public institutions, 28 Nov 2018	justice.gov	2026-11-11	Confirmed (allegations)
66	US DOJ, Justice Department announces actions to dismantle Kelihos botnet, 10 Apr 2017	justice.gov	2026-11-11	Confirmed
67	US DOJ, AlphaBay, the largest online "dark market", shut down, 20 Jul 2017	justice.gov	2026-11-11	Confirmed
68	US Attorney's Office N.D. Cal., Russian national and bitcoin exchange charged in 21-count indictment, 26 Jul 2017	justice.gov	2026-11-11	Confirmed (allegations)

#	Source	URL	Opened	Grade
69	US DOJ, Justice Department announces charges and guilty pleas in three computer crime cases involving significant DDoS attacks, 13 Dec 2017	justice.gov	2026-11-11	Confirmed
70	Europol, Andromeda botnet dismantled in international cyber operation, 4 Dec 2017	europol.europa.eu	2026-11-11	Confirmed
71	FBI IC3, 2017 Internet Crime Report (PDF)	ic3.gov	2026-11-11	Confirmed
72	Microsoft MSRC, CVRF security update documents for 2017 (the 2017-May document, with the other 2017 monthly documents at the same path)	api.msrc.microsoft.com	2026-11-11	Confirmed
73	Microsoft MSRC, CVRF security update document 2017-Apr	api.msrc.microsoft.com	2026-11-11	Confirmed
74	Google Project Zero, "0day In the Wild" tracker, 2017 tab	docs.google.com	2026-11-11	Confirmed
75	NIST NVD, CVE-2017-11882 record (API 2.0; the CVE-2017-0199 and CVE-2017-8759 records at the same path)	services.nvd.nist.gov	2026-11-11	Confirmed
76	NIST NVD, CVE-2017-0144 record (API 2.0)	services.nvd.nist.gov	2026-11-11	Confirmed
77	ESET WeLiveSecurity, Analysis of TeleBots' cunning backdoor, 4 Jul 2017	welivesecurity.com	2026-11-11	Reported
78	Equifax investor relations, Equifax announces cybersecurity incident involving consumer information, 7 Sep 2017	investor.equifax.com	2026-11-11	Confirmed
79	CISA (US-CERT), TA17-163A, CrashOverride Malware, 12 Jun 2017, revised 20 Jul 2021	cisa.gov	2026-11-11	Confirmed
80	Federal Register, Executive Order 13800, Strengthening the Cybersecurity of Federal Networks and Critical Infrastructure, 16 May 2017	govinfo.gov	2026-11-11	Confirmed
81	New York State Department of Financial Services, Cybersecurity Resource Center (23 NYCRR Part 500)	dfs.ny.gov	2026-11-11	Confirmed
82	US Congress, Public Law 115-91, National Defense Authorization Act for Fiscal Year 2018, 12 Dec 2017	govinfo.gov	2026-11-11	Confirmed
83	US SEC, press release 2017-176, SEC announces enforcement initiatives to combat cyber-based threats, 25 Sep 2017	`https://www.sec.gov/news/press-release/2017-176`	2026-11-11	Confirmed
84	The White House (archive), Vulnerabilities Equities Policy and Process for the United States Government, 15 Nov 2017 (PDF)	trumpwhitehouse.archives.gov	2026-11-11	Confirmed
85	MITRE ATT&CK, software S0366 WannaCry (site at content v20.1)	attack.mitre.org	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
86	Cisco Talos, The MeDoc Connection, 5 Jul 2017	blog.talosintelligence.com	2026-11-11	Confirmed (Talos findings); Reported (ESET's relayed DLL analysis and the police count)
87	MITRE ATT&CK, software S0368 NotPetya	attack.mitre.org	2026-11-11	Confirmed
88	CISA (US-CERT), TA17-117A, Intrusions Affecting Multiple Victims Across Multiple Sectors, 27 Apr 2017, revised 20 Dec 2018	cisa.gov	2026-11-11	Confirmed
89	MITRE ATT&CK, campaign C0030, Triton Safety Instrumented System Attack	attack.mitre.org	2026-11-11	Confirmed
90	MITRE ATT&CK, software S1009 Triton (site at content v20.1, modified 12 May 2026)	attack.mitre.org	2026-11-11	Confirmed
91	CISA, ICSA-18-107-02, Schneider Electric Triconex Tricon (Update B), revised 18 Dec 2018	cisa.gov	2026-11-11	Confirmed
92	Microsoft MSRC, CVRF security update document 2017-Nov, November 2017 Security Updates, released 14 Nov 2017 (CVE-2017-11882: Exploited: No)	api.msrc.microsoft.com	2026-11-11	Confirmed
93	Mathy Vanhoef, Key Reinstallation Attacks: Breaking WPA2 by forcing nonce reuse, the researcher's disclosure account (vendor notification around 14 July 2017, CERT/CC broad notification 28 August 2017, ACM CCS presentation Wednesday 1 November 2017)	krackattacks.com	2026-11-11	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- CWE Reference, CAPEC Reference, D3FEND Reference
- Ransomware Defense, ICS and OT Security, ICS ATT&CK Atlas, Supply Chain Security, Cloud Attack Reference

- Home studies: Sandworm; North Korea-attributed actors; United States-attributed actors; Russia-attributed actors; China-attributed actors; Iran-attributed actors; Other state-linked actors; APT41: the public record
- Related studies: SolarWinds and SUNBURST; npm supply-chain attacks; Stuxnet; ICS attacks and advisories, 2024 to 2026; Log4Shell; Hugging Face supply chain; The zero-day trade and its fallout; Cyber operations as statecraft: the cases in The Hacker and the State; Five hacks and why they worked: the cases in Fancy Bear Goes Phishing
- Series: 2019, 2020, 2021
- Groups: G0032 Lazarus Group, G0034 Sandworm Team, G0035 Dragonfly, G0045 menuPass, G0088 TEMP.Veles, G0022 APT3, G0064 APT33, G0049 OilRig, G0050 APT32, G0020 Equation
- Software: S0366 WannaCry, S0368 NotPetya, S0606 Bad Rabbit, S0370 SamSam, S1074 ANDROMEDA, S0140 Shamoon, S0596 ShadowPad, S0181 FALLCHILL, S0180 Volgmer, S0013 PlugX, S0153 RedLeaves, S0002 Mimikatz, S0029 PsExec, S0604 Industroyer
- Campaigns: C0030 Triton Safety Instrumented System Attack
- Techniques: T1210 Exploitation of Remote Services, T1486 Data Encrypted for Impact, T1195.002 Compromise Software Supply Chain, T1199 Trusted Relationship, T1003.001 LSASS Memory, T1021.002 SMB/Windows Admin Shares, T1190 Exploit Public-Facing Application, T1187 Forced Authentication, T1561.002 Disk Structure Wipe
- CAPEC: CAPEC-186, CAPEC-187, CAPEC-206, CAPEC-561, CAPEC-100
- Navigator layers, including this study's layers, chronicle-2017.json and chronicle-2017-ics.json